Fortify Software Security Center

Vulnerability Report

Credit Risk Dossier - v1



Table of Contents

Executive Summary
Project Description
Vulnerabilities by URL/Location
Security Issues Summary
Security Issues Details
Category Descriptions

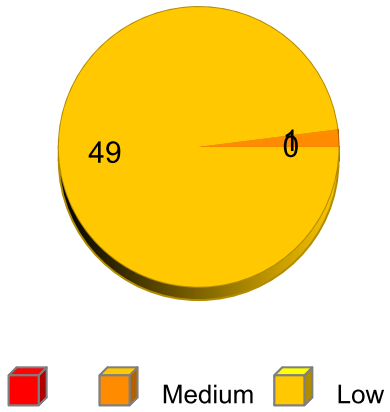


Executive Summary

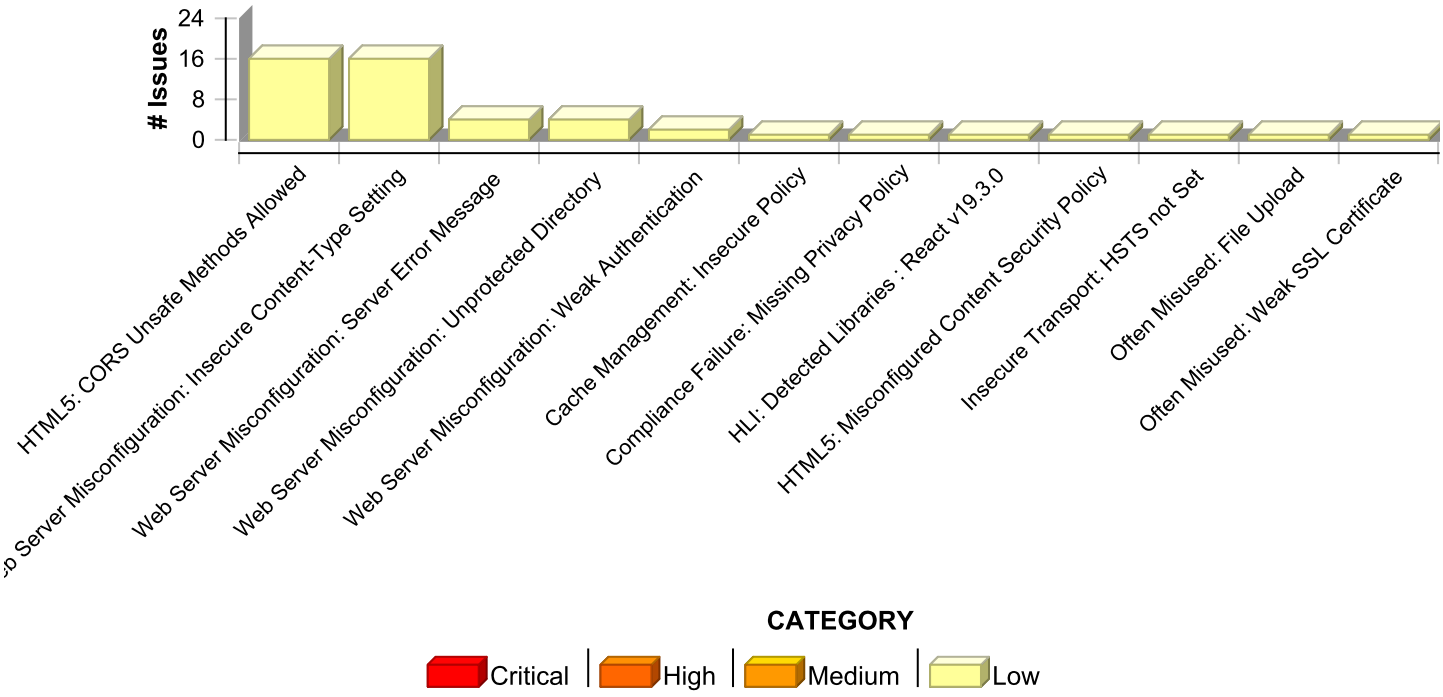
This report provides an analysis of the security risk posed by the projects current standing. It presents the vulnerability category and severity level distributions across the entire project. The information contained in this report will enable project managers to evaluate the security posture of the project and prioritize outstanding issues that require immediate attention.

Project Name:	Credit Risk Dossier
Project Version:	v1
SCA:	Results Not Present
WebInspect:	Results Present
WebInspect Agent:	Results Not Present
Other:	Results Not Present

Vulnerability By Priority



Vulnerability By Threat Class (Top 12)



© Copyright 2008-2026 Open Text.

Project Description

This section provides an overview of the Fortify scan engines used for this project, as well as the project meta-information.

WEBINSPECT

Date of Last Analysis:	6 Oct 2026 12:45 pm	**Engine Version:**	26.2
Host Name:		**Certification:**	NOT_PRESENT
Number of Files:	0	**Lines of Code:**	0

Accessibility	Internal Network Access Required
Development Phase	New
Development Strategy	Internally Developed

© Copyright 2008-2026 Open Text.

Vulnerabilities by URL/Location

URLLOCATION	Fortify Priority (audited/total)				Total Issues
	Critical	High	Medium	Low	
https:/credit-dossier-ip-safe.up.railway.app:443/	0	0	0	0 / 3	0 / 3
https:/credit-dossier-ip-safe.up.railway.app:443/api/deals/deal_9bf5309/sections/deal_9bf5309_relationship_summary	0	0	0	0 / 3	0 / 3
https:/credit-dossier-ip-safe.up.railway.app:443/admin/	0	0	0	0 / 2	0 / 2
https:/credit-dossier-ip-safe.up.railway.app:443/api/auth/me	0	0	0	0 / 2	0 / 2
https:/credit-dossier-ip-safe.up.railway.app:443/api/companies/Creditprime/details	0	0	0	0 / 2	0 / 2
https:/credit-dossier-ip-safe.up.railway.app:443/api/deals	0	0	0	0 / 2	0 / 2
https:/credit-dossier-ip-safe.up.railway.app:443/api/deals/deal_9bf5309	0	0	0	0 / 2	0 / 2
https:/credit-dossier-ip-safe.up.railway.app:443/api/deals/deal_9bf5309/export/pdf	0	0	0	0 / 2	0 / 2
https:/credit-dossier-ip-safe.up.railway.app:443/api/deals/deal_9bf5309/report	0	0	0	0 / 2	0 / 2
https:/credit-dossier-ip-safe.up.railway.app:443/api/deals/deal_9bf5309/sections/deal_9bf5309_client_overview/edit-lock	0	0	0	0 / 2	0 / 2
https:/credit-dossier-ip-safe.up.railway.app:443/api/deals/deal_9bf5309/sections/deal_9bf5309_executive_summary/edit-lock	0	0	0	0 / 2	0 / 2
https:/credit-dossier-ip-safe.up.railway.app:443/api/deals/deal_9bf5309/sections/deal_9bf5309_executive_summary/template	0	0	0	0 / 2	0 / 2
https:/credit-dossier-ip-safe.up.railway.app:443/api/deals/deal_9bf5309/versions	0	0	0	0 / 2	0 / 2
https:/credit-dossier-ip-safe.up.railway.app:443/admin	0	0	0	0 / 1	0 / 1
https:/credit-dossier-ip-safe.up.railway.app:443/api/auth/account-status	0	0	0	0 / 1	0 / 1
https:/credit-dossier-ip-safe.up.railway.app:443/api/auth/configuration	0	0	0	0 / 1	0 / 1
https:/credit-dossier-ip-safe.up.railway.app:443/api/auth/login	0	0	0	0 / 1	0 / 1
https:/credit-dossier-ip-safe.up.railway.app:443/api/companies	0	0	0	0 / 1	0 / 1
https:/credit-dossier-ip-safe.up.railway.app:443/api/companies/	0	0	0	0 / 1	0 / 1
https:/credit-dossier-ip-safe.up.railway.app:443/api/deals/deal_9bf5309/export/docx	0	0	0	0 / 1	0 / 1
https:/credit-dossier-ip-safe.up.railway.app:443/api/deals/deal_9bf5309/export/pptx	0	0	0	0 / 1	0 / 1
https:/credit-dossier-ip-safe.up.railway.app:443/api/deals/deal_9bf5309/sections/deal_9bf5309_client_overview	0	0	0	0 / 1	0 / 1
https:/credit-dossier-ip-safe.up.railway.app:443/api/deals/deal_9bf5309/sections/deal_9bf5309_client_overview/versions	0	0	0	0 / 1	0 / 1
https:/credit-dossier-ip-safe.up.railway.app:443/api/deals/deal_9bf5309/sections/deal_9bf5309_client_overview/versions/nv_7fe1905781	0	0	0	0 / 1	0 / 1
https:/credit-dossier-ip-safe.up.railway.app:443/api/deals/deal_9bf5309/sections/deal_9bf5309_relationship_summary/edit-lock	0	0	0	0 / 1	0 / 1
https:/credit-dossier-ip-safe.up.railway.app:443/api/deals/deal_9bf5309/theme/	0	0	0	0 / 1	0 / 1

© Copyright 2008-2026 Open Text.

URLLOCATION	Fortify Priority (audited/total)				Total Issues
	Critical	High	Medium	Low	
https:/credit-dossier-ip-safe.up.railway.app:443/api/deals/deal_9bf5309/theme/)LQJ4@b/TBA8]ZbIJ5qg	0	0	0	0 / 1	0 / 1
https:/credit-dossier-ip-safe.up.railway.app:443/api/deals/deal_9bf5309/versions/	0	0	0	0 / 1	0 / 1
https:/credit-dossier-ip-safe.up.railway.app:443/api/deals/deal_9bf5309/versions/v_0b2882/download	0	0	0	0 / 1	0 / 1
https:/credit-dossier-ip-safe.up.railway.app:443/api/deals/search	0	0	0	0 / 1	0 / 1
https:/credit-dossier-ip-safe.up.railway.app:443/assets/jsx-runtime-D3jfb0Ew.js	0	0	0	0 / 1	0 / 1
https:/credit-dossier-ip-safe.up.railway.app:443/assets/search-Dx8hvHZn.js	0	0	0	0 / 1	0 / 1
https:/credit-dossier-ip-safe.up.railway.app:443/assets/triangle-alert-BfPUAUia.js HTTP/1.1/../../triangle-alert-BfPUAUia.js	0	0	0 / 1	0	0 / 1
https:/credit-dossier-ip-safe.up.railway.app:443/dashboard/	0	0	0	0 / 1	0 / 1
https:/credit-dossier-ip-safe.up.railway.app:443/login/	0	0	0	0 / 1	0 / 1

© Copyright 2008-2026 Open Text.

Security Issues Summary

This report provides a comprehensive list of locations in the application where each vulnerability was discovered. Developers and project managers can also use it to apply a severity filter to the vulnerability results.

Medium

Path Manipulation: Special Characters	1 Issue
https:/credit-dossier-ip-safe.up.railway.app:443/assets/triangle-alert-BfPUAUia.jsHTTP/1.1/../../triangle-alert-BfPUAUia.js	1

Low

HTML5: CORS Unsafe Methods Allowed	16 Issues
https:/credit-dossier-ip-safe.up.railway.app:443/api/auth/me	1
https:/credit-dossier-ip-safe.up.railway.app:443/api/companies/	1
https:/credit-dossier-ip-safe.up.railway.app:443/api/companies/Creditprime/details	1
https:/credit-dossier-ip-safe.up.railway.app:443/api/deals	1
https:/credit-dossier-ip-safe.up.railway.app:443/api/deals/deal_9bf5309	1
https:/credit-dossier-ip-safe.up.railway.app:443/api/deals/deal_9bf5309/export/pdf	1
https:/credit-dossier-ip-safe.up.railway.app:443/api/deals/deal_9bf5309/sections/deal_9bf5309_client_overview/edit-lock	1
https:/credit-dossier-ip-safe.up.railway.app:443/api/deals/deal_9bf5309/sections/deal_9bf5309_client_overview/versions/nv_7fe1905781	1
https:/credit-dossier-ip-safe.up.railway.app:443/api/deals/deal_9bf5309/sections/deal_9bf5309_executive_summary/edit-lock	1
https:/credit-dossier-ip-safe.up.railway.app:443/api/deals/deal_9bf5309/sections/deal_9bf5309_relationship_summary	1
https:/credit-dossier-ip-safe.up.railway.app:443/api/deals/deal_9bf5309/sections/deal_9bf5309_relationship_summary/edit-lock	1
https:/credit-dossier-ip-safe.up.railway.app:443/api/deals/deal_9bf5309/theme/	1
https:/credit-dossier-ip-safe.up.railway.app:443/api/deals/deal_9bf5309/theme/)LQJ4@b/TBA8]ZbIJ5qg	1
https:/credit-dossier-ip-safe.up.railway.app:443/api/deals/deal_9bf5309/versions	1
https:/credit-dossier-ip-safe.up.railway.app:443/api/deals/deal_9bf5309/versions/	1
https:/credit-dossier-ip-safe.up.railway.app:443/api/deals/deal_9bf5309/versions/	1

© Copyright 2008-2026 Open Text.

v_0b2882/download	
Web Server Misconfiguration: Insecure Content-Type Setting	**16 Issues**
https:/credit-dossier-ip-safe.up.railway.app:443/api/auth/account-status	1
https:/credit-dossier-ip-safe.up.railway.app:443/api/auth/configuration	1
https:/credit-dossier-ip-safe.up.railway.app:443/api/auth/login	1
https:/credit-dossier-ip-safe.up.railway.app:443/api/companies	1
https:/credit-dossier-ip-safe.up.railway.app:443/api/companies/Creditprime/details	1
https:/credit-dossier-ip-safe.up.railway.app:443/api/deals	1
https:/credit-dossier-ip-safe.up.railway.app:443/api/deals/deal_9bf5309	1
https:/credit-dossier-ip-safe.up.railway.app:443/api/deals/deal_9bf5309/report	1
https:/credit-dossier-ip-safe.up.railway.app:443/api/deals/deal_9bf5309/sections/deal_9bf5309_client_overview	1
https:/credit-dossier-ip-safe.up.railway.app:443/api/deals/deal_9bf5309/sections/deal_9bf5309_client_overview/edit-lock	1
https:/credit-dossier-ip-safe.up.railway.app:443/api/deals/deal_9bf5309/sections/deal_9bf5309_client_overview/versions	1
https:/credit-dossier-ip-safe.up.railway.app:443/api/deals/deal_9bf5309/sections/deal_9bf5309_executive_summary/edit-lock	1
https:/credit-dossier-ip-safe.up.railway.app:443/api/deals/deal_9bf5309/sections/deal_9bf5309_executive_summary/template	1
https:/credit-dossier-ip-safe.up.railway.app:443/api/deals/deal_9bf5309/sections/deal_9bf5309_relationship_summary	1
https:/credit-dossier-ip-safe.up.railway.app:443/api/deals/deal_9bf5309/versions	1
https:/credit-dossier-ip-safe.up.railway.app:443/api/deals/search	1
Web Server Misconfiguration: Server Error Message	**4 Issues**
https:/credit-dossier-ip-safe.up.railway.app:443/api/deals/deal_9bf5309/export/docx	1
https:/credit-dossier-ip-safe.up.railway.app:443/api/deals/deal_9bf5309/export/pdf	1
https:/credit-dossier-ip-safe.up.railway.app:443/api/deals/deal_9bf5309/export/pptx	1
https:/credit-dossier-ip-safe.up.railway.app:443/api/deals/deal_9bf5309/report	1
Web Server Misconfiguration: Unprotected Directory	**4 Issues**
https:/credit-dossier-ip-safe.up.railway.app:443/admin/	2
https:/credit-dossier-ip-safe.up.railway.app:443/dashboard/	1
https:/credit-dossier-ip-safe.up.railway.app:443/login/	1
	2 Issues

© Copyright 2008-2026 Open Text.

Web Server Misconfiguration: Weak Authentication	
https:/credit-dossier-ip-safe.up.railway.app:443/api/auth/me	1
https:/credit-dossier-ip-safe.up.railway.app:443/api/deals/deal_9bf5309/sections/deal_9bf5309_relationship_summary	1
Cache Management: Insecure Policy	**1 Issue**
https:/credit-dossier-ip-safe.up.railway.app:443/	1
Compliance Failure: Missing Privacy Policy	**1 Issue**
https:/credit-dossier-ip-safe.up.railway.app:443/	1
HLI: Detected Libraries : React v19.3.0	**1 Issue**
https:/credit-dossier-ip-safe.up.railway.app:443/admin	1
HTML5: Misconfigured Content Security Policy	**1 Issue**
https:/credit-dossier-ip-safe.up.railway.app:443/	1
Insecure Transport: HSTS not Set	**1 Issue**
https:/credit-dossier-ip-safe.up.railway.app:443/assets/jsx-runtime-D3jfb0Ew.js	1
Often Misused: File Upload	**1 Issue**
https:/credit-dossier-ip-safe.up.railway.app:443/api/deals/deal_9bf5309/sections/deal_9bf5309_executive_summary/template	1
Often Misused: Weak SSL Certificate	**1 Issue**
https:/credit-dossier-ip-safe.up.railway.app:443/assets/search-Dx8hvHZn.js	1

© Copyright 2008-2026 Open Text.

Security Issues Details

This report details each vulnerability discovered during the audit. Detailed information such as the vulnerable parameters, steps to reproduce the issue and the recommended remediation enable the resolution of the coding errors affecting each of the reported vulnerabilities.

Cache Management: Insecure Policy	Low
URL: https://credit-dossier-ip-safe.up.railway.app:443/	
https://credit-dossier-ip-safe.up.railway.app:443/ (Cache Management: Insecure Policy)	Low

Issue Details

Kingdom: Environment
Scan Engine: WEBINSPECT (Dynamic Analysis)
CWE: CWE ID 525

Request

GET / HTTP/1.1
Host: credit-dossier-ip-safe.up.railway.app
Sec-Ch-Ua: "Not;A=Brand";v="8", "Chromium";v="150"
Sec-Ch-Ua-Mobile: ?0
Sec-Ch-Ua-Platform: "Windows"
Accept-Language: en-US,en;q=0.9
Upgrade-Insecure-Requests: 1
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/150.0.0.0 Safari/537.36
Accept: */*
Sec-Fetch-Site: none
Sec-Fetch-Mode: navigate
Sec-Fetch-User: ?1
Sec-Fetch-Dest: document
Accept-Encoding: gzip, deflate
Priority: u=0, i
Pragma: no-cache
Connection: Keep-Alive
X-WIPP: AscVersion=26.2.0.55
X-RequestManager-Memo:
Category="TrafficMacro.NamedMacro";MacroName="WebProxyGenerated";trid="48ea27e4";stid="109

X-Scan-Memo:
Category="Macro";SID="3762DE85075728E77DD5CE6431933650";SessionType="NamedMacro";Cra

X-Request-Memo: rid="b13ee80e";sc="1";thid="128";
Cookie: CustomCookie=WebInspect209950ZXFA7CF6531B49486793E4B5D01CE6C4F4Y9EB5

Response

HTTP/1.1 200 OK
content-security-policy: def...TRUNCATED...

© Copyright 2008-2026 Open Text.

Compliance Failure: Missing Privacy Policy	Low
URL: https://credit-dossier-ip-safe.up.railway.app:443/	
https://credit-dossier-ip-safe.up.railway.app:443/ (Compliance Failure: Missing Privacy Policy)	Low

Issue Details

Kingdom: Security Features
Scan Engine: WEBINSPECT (Dynamic Analysis)

Request

```
GET / HTTP/1.1
Host: credit-dossier-ip-safe.up.railway.app
Sec-Ch-Ua: "Not;A=Brand";v="8", "Chromium";v="150"
Sec-Ch-Ua-Mobile: ?0
Sec-Ch-Ua-Platform: "Windows"
Accept-Language: en-US,en;q=0.9
Upgrade-Insecure-Requests: 1
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko)
Chrome/150.0.0.0 Safari/537.36
Accept: */*
Sec-Fetch-Site: none
Sec-Fetch-Mode: navigate
Sec-Fetch-User: ?1
Sec-Fetch-Dest: document
Accept-Encoding: gzip, deflate
Priority: u=0, i
Pragma: no-cache
Connection: Keep-Alive
X-WIPP: AscVersion=26.2.0.55
X-RequestManager-Memo:
Category="TrafficMacro.NamedMacro";MacroName="WebProxyGenerated";trid="48ea27e4";stid="109

X-Scan-Memo:
Category="Macro";SID="3762DE85075728E77DD5CE6431933650";SessionType="NamedMacro";Cra

X-Request-Memo: rid="b13ee80e";sc="1";thid="128";
Cookie: CustomCookie=WebInspect209950ZXFA7CF6531B49486793E4B5D01CE6C4F4Y9EB5
```

Response

```
HTTP/1.1 200 OK
content-security-policy: default-src 'self'; base-uri 'self'; object-src 'none'; frame-ancestors 'none'; form-
action 'self'; script-src 'self' 'unsafe-inline'; style-src 'self' 'unsafe-inline'; img-src 'self' data: blob:; font-
src 'self' data:; connect-src 'self'
Content-Type: text/html; charset=utf-8
Date: Tue, 06 Oct 2026 07:16:05 GMT
permissions-policy: camera=(), microphone=(), geolocation=(), payment=(), usb=()
referrer-policy: no-referrer
Server: railway-hikari
x-content-type-options: nosniff
x-frame-options: DENY
x-railway-request-id: 1VJkwT2TRmak4lXX0_TJvA
x-hikari-trace: sin1.d1nj
x-railway-edge: sin1
```


© Copyright 2008-2026 Open Text.

Compliance Failure: Missing Privacy Policy	Low

URL: https://credit-dossier-ip-safe.up.railway.app:443/

https://credit-dossier-ip-safe.up.railway.app:443/ (Compliance Failure: Missing Privacy Policy)	Low

Connection: keep-alive
Content-Length: 2625

<!DOCTYPE html><html lang="en"><head><meta charSet="utf-8"/><meta name="viewport" content="width=device-width, initial-scale=1"/><link rel="stylesheet" href="/assets/styles-DGojK3RI.css" data-precedence="default"/><title>Credit Pitch Book Pipeline</title><meta name="author" content="Credit Dossier"/><meta property="og:title" content="Credit Dossier Dashboard"/><meta property="og:description" content="Credit Dossier Management Dashboard"/><meta property="og:type" content="website"/><meta name="twitter:card" content="summary"/><meta name="description" content="Initiate, draft, review, and export pitch books with full traceability."/><link rel="modulepreload" href="/assets/index-BHMdI9Xr.js"/><link rel="modulepreload" href="/assets/jsx-runtime-D3jfb0Ew.js"/><link rel="modulepreload" href="/assets/routes-CuLrcUhx.js"/><link rel="modulepreload" href="/assets/circle-check-CsAv3tyK.js"/><link rel="modulepreload" href="/assets/triangle-alert-BfPUAUia.js"/><link rel="modulepreload" href="/assets/file-text-BuUlmC52.js"/><link rel="modulepreload" href="/assets/loader-circle-CyKWCFFW.js"/><link rel="modulepreload" href="/assets/search-Dx8hvHZn.js"/><link rel="modulepreload" href="/assets/deals-BwsNx4FC.js"/></head><body> <div cla...TRUNCATED...

HLI: Detected Libraries : React v19.3.0	Low

URL: https://credit-dossier-ip-safe.up.railway.app:443/admin

https://credit-dossier-ip-safe.up.railway.app:443/admin (HLI: Detected Libraries : React v19.3.0)	Low

Issue Details

Scan Engine: WEBINSPECT (Dynamic Analysis)

Request

GET /admin HTTP/1.1
Referer: https://credit-dossier-ip-safe.up.railway.app/admin/
Accept: */*
Pragma: no-cache
Accept-Encoding: gzip, deflate
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:130.0) Gecko/20100101 Firefox/130.0
Host: credit-dossier-ip-safe.up.railway.app
Connection: Keep-Alive
X-WIPP: AscVersion=26.2.0.55
X-Scan-Memo:
Category="Crawl";SID="7C65F75112CEE998D945BC89303C682A";PSID="FFCC5F06F4586A6B9DD

X-RequestManager-Memo: stid="109";stmi="0";sc="1";rid="56b8efc9";
X-Request-Memo: rid="053192eb";sc="1";thid="69";
Cookie: CustomCookie=WebInspect209950ZXFA7CF6531B49486793E4B5D01CE6C4F4Y9EB5

Response

HTTP/1.1 200 OK
content-security-policy: default-src 'self'; base-uri 'self'; object-src 'none'; frame-ancestors 'none'; form-

© Copyright 2008-2026 Open Text.

HLI: Detected Libraries : React v19.3.0	Low
URL: https://credit-dossier-ip-safe.up.railway.app:443/admin	
https://credit-dossier-ip-safe.up.railway.app:443/admin (HLI: Detected Libraries : React v19.3.0)	**Low**

action 'self'; script-src 'self' 'unsafe-inline'; style-src 'self' 'unsafe-inline'; img-src 'self' data: blob:; font-src 'self' data:; connect-src 'self'
Content-Type: text/html; charset=utf-8
Date: Tue, 06 Oct 2026 07:29:39 GMT
permissions-policy: camera=(), microphone=(), geolocation=(), payment=(), usb=()
referrer-policy: no-referrer
Server: railway-hikari
x-content-type-options: nosniff
x-frame-options: DENY
x-railway-request-id: eoXk9lBhSVyTncg2pHNmDw
x-hikari-trace: sin1.tr00
x-railway-edge: sin1
Connection: keep-alive
Content-Length: 2413

<!DOCTYPE html><html lang="en"><head><meta charSet="utf-8"/><meta name="viewport" content="width=device-width, initial-scale=1"/><link rel="stylesheet" href="/assets/styles-DGojK3RI.css" data-precedence="default"/><title>Admin dashboard | Credit Pitch Book</title><meta name="description" content="Credit Dossier Management Dashboard"/><meta name="author" content="Credit Dossier"/><meta property="og:title" content="Credit Dossier Dashboard"/><meta property="og:description" content="Credit Dossier Management Dashboard"/><meta property="og:type" content="website"/><meta name="twitter:card" content="summary"/><link rel="modulepreload" href="/assets/index-BHMdI9Xr.js"/><link rel="modulepreload" href="/assets/jsx-runtime-D3jfb0Ew.js"/><link rel="modulepreload" href="/assets/admin-B_LZfOBq.js"/><link rel="modulepreload" href="/assets/circle-check-CsAv3tyK.js"/><link rel="modulepreload" href="/assets/key-round-B9KCyO-_.js"/><link rel="modulepreload" href="/assets/loader-circle-CyKWCFFW.js"/><link rel="modulepreload" href="/assets/save-C8BMNXlC.js"/></head><body> <script data-tsr-stream-part="">(self.$R=self.$R||{})["tsr"]=[]...TRUNCATED...

HTML5: CORS Unsafe Methods Allowed	Low
URL: https://credit-dossier-ip-safe.up.railway.app:443/api/auth/me	
https://credit-dossier-ip-safe.up.railway.app:443/api/auth/me (HTML5: CORS Unsafe Methods Allowed)	**Low**

Issue Details

Kingdom: Encapsulation
Scan Engine: WEBINSPECT (Dynamic Analysis)
CWE: CWE ID 749

Request

OPTIONS /api/auth/me HTTP/1.1
Host: credit-dossier-ip-safe.up.railway.app
Pragma: no-cache
Sec-Ch-Ua-Platform: "Windows"
Accept-Language: en-US,en;q=0.9
Sec-Ch-Ua: "Not;A=Brand";v="8", "Chromium";v="150"

© Copyright 2008-2026 Open Text.

HTML5: CORS Unsafe Methods Allowed	Low

URL: https://credit-dossier-ip-safe.up.railway.app:443/api/auth/me

https://credit-dossier-ip-safe.up.railway.app:443/api/auth/me (HTML5: CORS Unsafe Methods Allowed)	Low

Content-Type: application/json
Sec-Ch-Ua-Mobile: ?0
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/150.0.0.0 Safari/537.36
Accept: */*
Sec-Fetch-Site: same-origin
Sec-Fetch-Mode: cors
Sec-Fetch-Dest: empty
Accept-Encoding: gzip, deflate
Priority: u=1, i
Access-Control-Request-Method: POST
Access-Control-Request-Headers: X-Pingsession
Origin: http://webinspect.microfocus.com
Referer: https://credit-dossier-ip-safe.up.railway.app/api/auth/me
Connection: Keep-Alive
X-WIPP: AscVersion=26.2.0.55
X-Scan-Memo:
Category="Audit.Attack";SID="AE7AEB2B3C8D85DB4C644F96D8E3BB90";PSID="F9DD5B8DCC1C3
b895-4666-
a9d2-026b0a4716c9";AttackSequence="0";AttackParamDesc="";AttackParamIndex="0";AttackParamS

X-RequestManager-Memo: sc="1";rid="99ef6eda";
X-Request-Memo: rid="19cc7954";sc="1";thid="86";
Cookie: CustomCookie=WebInspect209950ZXFA7CF6531B49486793E4B5D01CE6C4F4Y9EB5

Response

...TRUNCATED...nguage, Content-Language, Content-Type
access-control-allow-methods: GET, HEAD, POST, PATCH, DELETE, OPTIONS
access-control-max-age: 600
Content-Typ...TRUNCATED...

URL: https://credit-dossier-ip-safe.up.railway.app:443/api/companies/

https://credit-dossier-ip-safe.up.railway.app:443/api/companies/ (HTML5: CORS Unsafe Methods Allowed)	Low

Issue Details

Kingdom: Encapsulation
Scan Engine: WEBINSPECT (Dynamic Analysis)
CWE: CWE ID 749

Request

OPTIONS /api/companies/ HTTP/1.1
Referer: https://credit-dossier-ip-safe.up.railway.app/api/companies/Creditprime/details
Accept: */*
Pragma: no-cache
Accept-Encoding: gzip, deflate
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:130.0) Gecko/20100101 Firefox/130.0

© Copyright 2008-2026 Open Text.

HTML5: CORS Unsafe Methods Allowed	Low

URL: https://credit-dossier-ip-safe.up.railway.app:443/api/companies/

https://credit-dossier-ip-safe.up.railway.app:443/api/companies/ (HTML5: CORS Unsafe Methods Allowed)	Low

Host: credit-dossier-ip-safe.up.railway.app
Access-Control-Request-Method: POST
Access-Control-Request-Headers: X-Pingsession
Origin: http://webinspect.microfocus.com
Connection: Keep-Alive
X-WIPP: AscVersion=26.2.0.55
X-Scan-Memo:
Category="Audit.Attack";SID="7D35D85ABF2198366737820066A1321C";PSID="944CFA42D54C347(
b895-4666-
a9d2-026b0a4716c9";AttackSequence="0";AttackParamDesc="";AttackParamIndex="0";AttackParamS

X-RequestManager-Memo: sc="1";rid="265caf1d";
X-Request-Memo: rid="666eb385";sc="1";thid="86";
Cookie: CustomCookie=WebInspect209950ZXFA7CF6531B49486793E4B5D01CE6C4F4Y9EB5

Response

...TRUNCATED...nguage, Content-Language, Content-Type
access-control-allow-methods: GET, HEAD, POST, PATCH, DELETE, OPTIONS
access-control-max-age: 600
Content-Typ...TRUNCATED...

URL: https://credit-dossier-ip-safe.up.railway.app:443/api/companies/Creditprime/details

https://credit-dossier-ip-safe.up.railway.app:443/api/companies/Creditprime/details (HTML5: CORS Unsafe Methods Allowed)	Low

Issue Details

Kingdom: Encapsulation
Scan Engine: WEBINSPECT (Dynamic Analysis)
CWE: CWE ID 749

Request

OPTIONS /api/companies/Creditprime/details HTTP/1.1
Host: credit-dossier-ip-safe.up.railway.app
Pragma: no-cache
Access-Control-Request-Method: POST
Access-Control-Request-Headers: X-Pingsession
Origin: http://webinspect.microfocus.com
Referer: https://credit-dossier-ip-safe.up.railway.app/api/companies/Creditprime/details
Connection: Keep-Alive
X-WIPP: AscVersion=26.2.0.55
X-Scan-Memo:
Category="Audit.Attack";SID="3F8E663EC1C2C9DB204ED6885D0BA016";PSID="7D0FC3494ACA7F
b895-4666-
a9d2-026b0a4716c9";AttackSequence="0";AttackParamDesc="";AttackParamIndex="0";AttackParamS

X-RequestManager-Memo: sc="1";rid="6aa18889";
X-Request-Memo: rid="32b74532";sc="1";thid="73";

© Copyright 2008-2026 Open Text.

HTML5: CORS Unsafe Methods Allowed — Low

URL: https://credit-dossier-ip-safe.up.railway.app:443/api/companies/Creditprime/details

https://credit-dossier-ip-safe.up.railway.app:443/api/companies/Creditprime/details (HTML5: CORS Unsafe Methods Allowed) — **Low**

Cookie: credit_dossier_session=DOCIYsfqpz7xbUnjBDXZg1m4803-7iA7L8FrxLsMUtfUb3-FJ4C2ntsn6ovP8Mqg;CustomCookie=WebInspect209950ZXFA7CF6531B49486793E4B5D01CE6C4F

Sec-Ch-Ua-Platform: "Windows"
Accept-Language: en-US,en;q=0.9
Sec-Ch-Ua: "Not;A=Brand";v="8", "Chromium";v="150"
Content-Type: application/json
Sec-Ch-Ua-Mobile: ?0
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/150.0.0.0 Safari/537.36
Accept: */*
Sec-Fetch-Site: same-origin
Sec-Fetch-Mode: cors
Sec-Fetch-Dest: empty
Accept-Encoding: gzip, deflate
Priority: u=1, i

Response

...TRUNCATED...nguage, Content-Language, Content-Type
access-control-allow-methods: GET, HEAD, POST, PATCH, DELETE, OPTIONS
access-control-max-age: 600
Content-Typ...TRUNCATED...

URL: https://credit-dossier-ip-safe.up.railway.app:443/api/deals

https://credit-dossier-ip-safe.up.railway.app:443/api/deals (HTML5: CORS Unsafe Methods Allowed) — **Low**

Issue Details

Kingdom: Encapsulation
Scan Engine: WEBINSPECT (Dynamic Analysis)
CWE: CWE ID 749

Request

OPTIONS /api/deals HTTP/1.1
Host: credit-dossier-ip-safe.up.railway.app
Pragma: no-cache
Sec-Ch-Ua-Platform: "Windows"
Accept-Language: en-US,en;q=0.9
Sec-Ch-Ua: "Not;A=Brand";v="8", "Chromium";v="150"
Content-Type: application/json
Sec-Ch-Ua-Mobile: ?0
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/150.0.0.0 Safari/537.36
Accept: */*
Sec-Fetch-Site: same-origin
Sec-Fetch-Mode: cors
Sec-Fetch-Dest: empty

© Copyright 2008-2026 Open Text.

HTML5: CORS Unsafe Methods Allowed — Low

URL: https://credit-dossier-ip-safe.up.railway.app:443/api/deals

https://credit-dossier-ip-safe.up.railway.app:443/api/deals (HTML5: CORS Unsafe Methods Allowed) — Low

Accept-Encoding: gzip, deflate
Priority: u=1, i
Access-Control-Request-Method: POST
Access-Control-Request-Headers: X-Pingsession
Origin: http://webinspect.microfocus.com
Referer: https://credit-dossier-ip-safe.up.railway.app/api/deals
Connection: Keep-Alive
X-WIPP: AscVersion=26.2.0.55
X-Scan-Memo:
Category="Audit.Attack";SID="B77DEF6CA2A99347130D5AEE8EFAE2B9";PSID="C2356D179DFDD9
b895-4666-
a9d2-026b0a4716c9";AttackSequence="0";AttackParamDesc="";AttackParamIndex="0";AttackParamS

X-RequestManager-Memo: sc="1";rid="48968f41";
X-Request-Memo: rid="9f13379d";sc="1";thid="73";
Cookie: CustomCookie=WebInspect209950ZXFA7CF6531B49486793E4B5D01CE6C4F4Y9EB5

Response

...TRUNCATED...nguage, Content-Language, Content-Type
access-control-allow-methods: GET, HEAD, POST, PATCH, DELETE, OPTIONS
access-control-max-age: 600
Content-Typ...TRUNCATED...

URL: https://credit-dossier-ip-safe.up.railway.app:443/api/deals/deal_9bf5309

https://credit-dossier-ip-safe.up.railway.app:443/api/deals/deal_9bf5309 (HTML5: CORS Unsafe Methods Allowed) — Low

Issue Details

Kingdom: Encapsulation
Scan Engine: WEBINSPECT (Dynamic Analysis)
CWE: CWE ID 749

Request

OPTIONS /api/deals/deal_9bf5309 HTTP/1.1
Host: credit-dossier-ip-safe.up.railway.app
Pragma: no-cache
Access-Control-Request-Method: POST
Access-Control-Request-Headers: X-Pingsession
Origin: http://webinspect.microfocus.com
Referer: https://credit-dossier-ip-safe.up.railway.app/api/deals/deal_9bf5309
Connection: Keep-Alive
X-WIPP: AscVersion=26.2.0.55
X-Scan-Memo:
Category="Audit.Attack";SID="9BA9413FD088F09581A546573BC58F36";PSID="36403363A4E9E997
b895-4666-
a9d2-026b0a4716c9";AttackSequence="0";AttackParamDesc="";AttackParamIndex="0";AttackParamS

© Copyright 2008-2026 Open Text.

HTML5: CORS Unsafe Methods Allowed	Low

URL: https://credit-dossier-ip-safe.up.railway.app:443/api/deals/deal_9bf5309

https://credit-dossier-ip-safe.up.railway.app:443/api/deals/deal_9bf5309 (HTML5: CORS Unsafe Methods Allowed)	Low

X-RequestManager-Memo: sc="1";rid="936cc4bf";
X-Request-Memo: rid="e60137f2";sc="1";thid="72";
Cookie: credit_dossier_session=d0eAPzIRp8QdGNrD2brN1Zr7r0-kEWvBBheaS1R6PKtDjB05Ngdyitb3WcLSs1uU;CustomCookie=WebInspect209950ZXFA7CF6531B4

Sec-Ch-Ua-Platform: "Windows"
Accept-Language: en-US,en;q=0.9
Sec-Ch-Ua: "Not;A=Brand";v="8", "Chromium";v="150"
Content-Type: application/json
Sec-Ch-Ua-Mobile: ?0
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/150.0.0.0 Safari/537.36
Accept: */*
Sec-Fetch-Site: same-origin
Sec-Fetch-Mode: cors
Sec-Fetch-Dest: empty
Accept-Encoding: gzip, deflate
Priority: u=1, i

Response

...TRUNCATED...nguage, Content-Language, Content-Type
access-control-allow-methods: GET, HEAD, POST, PATCH, DELETE, OPTIONS
access-control-max-age: 600
Content-Typ...TRUNCATED...

URL: https://credit-dossier-ip-safe.up.railway.app:443/api/deals/deal_9bf5309/export/pdf

https://credit-dossier-ip-safe.up.railway.app:443/api/deals/deal_9bf5309/export/pdf (HTML5: CORS Unsafe Methods Allowed)	Low

Issue Details

Kingdom: Encapsulation
Scan Engine: WEBINSPECT (Dynamic Analysis)
CWE: CWE ID 749

Request

OPTIONS /api/deals/deal_9bf5309/export/pdf HTTP/1.1
Host: credit-dossier-ip-safe.up.railway.app
Pragma: no-cache
Access-Control-Request-Method: POST
Access-Control-Request-Headers: X-Pingsession
Referer: https://credit-dossier-ip-safe.up.railway.app/api/deals/deal_9bf5309/export/pdf
Connection: Keep-Alive
X-WIPP: AscVersion=26.2.0.55
X-Scan-Memo:
Category="Audit.Attack";SID="1A7D239583124FD5ABAD438F5E05C295";PSID="2677C0360EF20BF
b895-4666-a9d2-026b0a4716c9";AttackSequence="0";AttackParamDesc="";AttackParamIndex="0";AttackParamS

© Copyright 2008-2026 Open Text.

HTML5: CORS Unsafe Methods Allowed	Low

URL: https://credit-dossier-ip-safe.up.railway.app:443/api/deals/deal_9bf5309/export/pdf

https://credit-dossier-ip-safe.up.railway.app:443/api/deals/deal_9bf5309/export/pdf (HTML5: CORS Unsafe Methods Allowed)	Low

X-RequestManager-Memo: sc="1";rid="f16c8f63";
X-Request-Memo: rid="b3ee0f8d";sc="1";thid="86";
Cookie: credit_dossier_session=DOCIYsfqpz7xbUnjBDXZg1m4803-7iA7L8FrxLsMUtfUb3-FJ4C2ntsn6ovP8Mqg;CustomCookie=WebInspect209950ZXFA7CF6531B49486793E4B5D01CE6C4F

Sec-Ch-Ua-Platform: "Windows"
Accept-Language: en-US,en;q=0.9
Sec-Ch-Ua: "Not;A=Brand";v="8", "Chromium";v="150"
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/150.0.0.0 Safari/537.36
Sec-Ch-Ua-Mobile: ?0
Accept: */*
Origin: http://webinspect.microfocus.com
Sec-Fetch-Site: same-origin
Sec-Fetch-Mode: cors
Sec-Fetch-Dest: empty
Accept-Encoding: gzip, deflate
Priority: u=1, i

Response

...TRUNCATED...nguage, Content-Language, Content-Type
access-control-allow-methods: GET, HEAD, POST, PATCH, DELETE, OPTIONS
access-control-max-age: 600
Content-Typ...TRUNCATED...

URL: https://credit-dossier-ip-safe.up.railway.app:443/api/deals/deal_9bf5309/sections/deal_9bf5309_client_overview/edit-lock

https://credit-dossier-ip-safe.up.railway.app:443/api/deals/deal_9bf5309/sections/deal_9bf5309_client_overview/edit-lock (HTML5: CORS Unsafe Methods Allowed)	Low

Issue Details

Kingdom: Encapsulation
Scan Engine: WEBINSPECT (Dynamic Analysis)
CWE: CWE ID 749

Request

OPTIONS /api/deals/deal_9bf5309/sections/deal_9bf5309_client_overview/edit-lock HTTP/1.1
Host: credit-dossier-ip-safe.up.railway.app
Pragma: no-cache
Access-Control-Request-Method: POST
Access-Control-Request-Headers: X-Pingsession
Referer: https://credit-dossier-ip-safe.up.railway.app/api/deals/deal_9bf5309/sections/deal_9bf5309_client_overview/edit-lock
Connection: Keep-Alive
X-WIPP: AscVersion=26.2.0.55
X-Scan-Memo:

© Copyright 2008-2026 Open Text.

HTML5: CORS Unsafe Methods Allowed	Low

URL: https://credit-dossier-ip-safe.up.railway.app:443/api/deals/deal_9bf5309/sections/deal_9bf5309_client_overview/edit-lock

https://credit-dossier-ip-safe.up.railway.app:443/api/deals/deal_9bf5309/sections/deal_9bf5309_client_overview/edit-lock (HTML5: CORS Unsafe Methods Allowed)	Low

Category="Audit.Attack";SID="A40988DA63E98257690FA7D9F604E4F9";PSID="95BD97CB7B71A3E
b895-4666-
a9d2-026b0a4716c9";AttackSequence="0";AttackParamDesc="";AttackParamIndex="0";AttackParamS

X-RequestManager-Memo: sc="1";rid="ea6713a7";
X-Request-Memo: rid="81e3fd68";sc="1";thid="72";
Cookie: credit_dossier_session=d0eAPzIRp8QdGNrD2brN1Zr7r0-
kEWvBBheaS1R6PKtDjB05Ngdyitb3WcLSs1uU;CustomCookie=WebInspect209950ZXFA7CF6531B4

Sec-Ch-Ua-Platform: "Windows"
Accept-Language: en-US,en;q=0.9
Sec-Ch-Ua: "Not;A=Brand";v="8", "Chromium";v="150"
Content-Type: application/json
Sec-Ch-Ua-Mobile: ?0
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko)
Chrome/150.0.0.0 Safari/537.36
Accept: */*
Origin: http://webinspect.microfocus.com
Sec-Fetch-Site: same-origin
Sec-Fetch-Mode: cors
Sec-Fetch-Dest: empty
Accept-Encoding: gzip, deflate
Priority: u=1, i

Response

...TRUNCATED...nguage, Content-Language, Content-Type
access-control-allow-methods: GET, HEAD, POST, PATCH, DELETE, OPTIONS
access-control-max-age: 600
Content-Typ...TRUNCATED...

URL: https://credit-dossier-ip-safe.up.railway.app:443/api/deals/deal_9bf5309/sections/deal_9bf5309_client_overview/versions/nv_7fe1905781

https://credit-dossier-ip-safe.up.railway.app:443/api/deals/deal_9bf5309/sections/deal_9bf5309_client_overview/versions/nv_7fe1905781 (HTML5: CORS Unsafe Methods Allowed)	Low

Issue Details

Kingdom: Encapsulation
Scan Engine: WEBINSPECT (Dynamic Analysis)
CWE: CWE ID 749

Request

OPTIONS /api/deals/deal_9bf5309/sections/deal_9bf5309_client_overview/versions/nv_7fe1905781
HTTP/1.1
Host: credit-dossier-ip-safe.up.railway.app
Pragma: no-cache

© Copyright 2008-2026 Open Text.

HTML5: CORS Unsafe Methods Allowed	Low

URL: https://credit-dossier-ip-safe.up.railway.app:443/api/deals/deal_9bf5309/sections/deal_9bf5309_client_overview/versions/nv_7fe1905781

https://credit-dossier-ip-safe.up.railway.app:443/api/deals/deal_9bf5309/sections/deal_9bf5309_client_overview/versions/nv_7fe1905781 (HTML5: CORS Unsafe Methods Allowed)	Low

Access-Control-Request-Method: POST
Access-Control-Request-Headers: X-Pingsession
Referer: https://credit-dossier-ip-safe.up.railway.app/api/deals/deal_9bf5309/sections/deal_9bf5309_client_overview/versions/nv_7fe1905781
Connection: Keep-Alive
X-WIPP: AscVersion=26.2.0.55
X-Scan-Memo:
Category="Audit.Attack";SID="C971CFC2F0E0E6F3C1D4A69B03F1BCF6";PSID="D8C175891BCC84
b895-4666-
a9d2-026b0a4716c9";AttackSequence="0";AttackParamDesc="";AttackParamIndex="0";AttackParamS

X-RequestManager-Memo: sc="1";rid="b2a6ffcb";
X-Request-Memo: rid="eaf68b4a";sc="1";thid="72";
Cookie: credit_dossier_session=d0eAPzIRp8QdGNrD2brN1Zr7r0-
kEWvBBheaS1R6PKtDjB05Ngdyitb3WcLSs1uU;CustomCookie=WebInspect209950ZXFA7CF6531B4

Sec-Ch-Ua-Platform: "Windows"
Accept-Language: en-US,en;q=0.9
Sec-Ch-Ua: "Not;A=Brand";v="8", "Chromium";v="150"
Content-Type: application/json
Sec-Ch-Ua-Mobile: ?0
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/150.0.0.0 Safari/537.36
Accept: */*
Origin: http://webinspect.microfocus.com
Sec-Fetch-Site: same-origin
Sec-Fetch-Mode: cors
Sec-Fetch-Dest: empty
Accept-Encoding: gzip, deflate
Priority: u=1, i

Response

...TRUNCATED...nguage, Content-Language, Content-Type
access-control-allow-methods: GET, HEAD, POST, PATCH, DELETE, OPTIONS
access-control-max-age: 600
Content-Typ...TRUNCATED...

URL: https://credit-dossier-ip-safe.up.railway.app:443/api/deals/deal_9bf5309/sections/deal_9bf5309_executive_summary/edit-lock

https://credit-dossier-ip-safe.up.railway.app:443/api/deals/deal_9bf5309/sections/deal_9bf5309_executive_summary/edit-lock (HTML5: CORS Unsafe Methods Allowed)	Low

Issue Details

Kingdom: Encapsulation
Scan Engine: WEBINSPECT (Dynamic Analysis)

© Copyright 2008-2026 Open Text.

HTML5: CORS Unsafe Methods Allowed	Low
URL: https://credit-dossier-ip-safe.up.railway.app:443/api/deals/deal_9bf5309/sections/deal_9bf5309_executive_summary/edit-lock	
https://credit-dossier-ip-safe.up.railway.app:443/api/deals/deal_9bf5309/sections/deal_9bf5309_executive_summary/edit-lock (HTML5: CORS Unsafe Methods Allowed)	Low

CWE: CWE ID 749

Request

```
OPTIONS /api/deals/deal_9bf5309/sections/deal_9bf5309_executive_summary/edit-lock HTTP/1.1
Host: credit-dossier-ip-safe.up.railway.app
Pragma: no-cache
Access-Control-Request-Method: POST
Access-Control-Request-Headers: X-Pingsession
Referer: https://credit-dossier-ip-safe.up.railway.app/api/deals/deal_9bf5309/sections/
deal_9bf5309_executive_summary/edit-lock
Connection: Keep-Alive
X-WIPP: AscVersion=26.2.0.55
X-Scan-Memo:
Category="Audit.Attack";SID="05E7B1D60B0D67192AD04C9B21EB3E54";PSID="0C2FEEA2E220E6(
b895-4666-
a9d2-026b0a4716c9";AttackSequence="0";AttackParamDesc="";AttackParamIndex="0";AttackParamS

X-RequestManager-Memo: sc="1";rid="67f46bec";
X-Request-Memo: rid="ade93fb5";sc="1";thid="114";
Cookie: credit_dossier_session=d0eAPzIRp8QdGNrD2brN1Zr7r0-
kEWvBBheaS1R6PKtDjB05Ngdyitb3WcLSs1uU;CustomCookie=WebInspect209950ZXFA7CF6531B4(

Sec-Ch-Ua-Platform: "Windows"
Accept-Language: en-US,en;q=0.9
Sec-Ch-Ua: "Not;A=Brand";v="8", "Chromium";v="150"
Content-Type: application/json
Sec-Ch-Ua-Mobile: ?0
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko)
Chrome/150.0.0.0 Safari/537.36
Accept: */*
Origin: http://webinspect.microfocus.com
Sec-Fetch-Site: same-origin
Sec-Fetch-Mode: cors
Sec-Fetch-Dest: empty
Accept-Encoding: gzip, deflate
Priority: u=1, i
```

Response

```
...TRUNCATED...nguage, Content-Language, Content-Type
access-control-allow-methods: GET, HEAD, POST, PATCH, DELETE, OPTIONS
access-control-max-age: 600
Content-Typ...TRUNCATED...
```


© Copyright 2008-2026 Open Text.

HTML5: CORS Unsafe Methods Allowed	Low

URL: https://credit-dossier-ip-safe.up.railway.app:443/api/deals/deal_9bf5309/sections/deal_9bf5309_relationship_summary

https://credit-dossier-ip-safe.up.railway.app:443/api/deals/deal_9bf5309/sections/deal_9bf5309_relationship_summary (HTML5: CORS Unsafe Methods Allowed)	Low

Issue Details

Kingdom: Encapsulation
Scan Engine: WEBINSPECT (Dynamic Analysis)
CWE: CWE ID 749

Request

```
OPTIONS /api/deals/deal_9bf5309/sections/deal_9bf5309_relationship_summary HTTP/1.1
Host: credit-dossier-ip-safe.up.railway.app
Pragma: no-cache
Access-Control-Request-Method: POST
Access-Control-Request-Headers: X-Pingsession
Referer: https://credit-dossier-ip-safe.up.railway.app/api/deals/deal_9bf5309/sections/
deal_9bf5309_relationship_summary
Connection: Keep-Alive
Content-Length: 70
X-WIPP: AscVersion=26.2.0.55
X-Scan-Memo:
Category="Audit.Attack";SID="CF909E78D6729BDEC5BCFCA408C85CBF";PSID="0D36A6154056D6
b895-4666-
a9d2-026b0a4716c9";AttackSequence="0";AttackParamDesc="";AttackParamIndex="0";AttackParamS

X-RequestManager-Memo: sc="1";rid="bfd4b3ae";
X-Request-Memo: rid="71795ff1";sc="1";thid="72";
Cookie: credit_dossier_session=d0eAPzIRp8QdGNrD2brN1Zr7r0-
kEWvBBheaS1R6PKtDjB05Ngdyitb3WcLSs1uU;CustomCookie=WebInspect209950ZXFA7CF6531B49

Sec-Ch-Ua-Platform: "Windows"
Accept-Language: en-US,en;q=0.9
Sec-Ch-Ua: "Not;A=Brand";v="8", "Chromium";v="150"
Content-Type: application/json
Sec-Ch-Ua-Mobile: ?0
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko)
Chrome/150.0.0.0 Safari/537.36
Accept: */*
Origin: http://webinspect.microfocus.com
Sec-Fetch-Site: same-origin
Sec-Fetch-Mode: cors
Sec-Fetch-Dest: empty
Accept-Encoding: gzip, deflate
Priority: u=1, i

{"custom_instructions":"forge some of the financial if not available"}
```

Response

```
...TRUNCATED...nguage, Content-Language, Content-Type
access-control-allow-methods: GET, HEAD, POST, PATCH, DELETE, OPTIONS
access-control-max-age: 600
```


© Copyright 2008-2026 Open Text.

HTML5: CORS Unsafe Methods Allowed	Low
URL: https://credit-dossier-ip-safe.up.railway.app:443/api/deals/deal_9bf5309/sections/deal_9bf5309_relationship_summary	
https://credit-dossier-ip-safe.up.railway.app:443/api/deals/deal_9bf5309/sections/deal_9bf5309_relationship_summary (HTML5: CORS Unsafe Methods Allowed)	Low

Content-Typ...TRUNCATED...

URL: https://credit-dossier-ip-safe.up.railway.app:443/api/deals/deal_9bf5309/sections/deal_9bf5309_relationship_summary/edit-lock	
https://credit-dossier-ip-safe.up.railway.app:443/api/deals/deal_9bf5309/sections/deal_9bf5309_relationship_summary/edit-lock (HTML5: CORS Unsafe Methods Allowed)	Low

Issue Details

Kingdom: Encapsulation
Scan Engine: WEBINSPECT (Dynamic Analysis)
CWE: CWE ID 749

Request

OPTIONS /api/deals/deal_9bf5309/sections/deal_9bf5309_relationship_summary/edit-lock HTTP/1.1
Host: credit-dossier-ip-safe.up.railway.app
Pragma: no-cache
Access-Control-Request-Method: POST
Access-Control-Request-Headers: X-Pingsession
Referer: https://credit-dossier-ip-safe.up.railway.app/api/deals/deal_9bf5309/sections/deal_9bf5309_relationship_summary/edit-lock
Connection: Keep-Alive
X-WIPP: AscVersion=26.2.0.55
X-Scan-Memo:
Category="Audit.Attack";SID="19D7ACEEFD4D57632FFFB8319C0873B3";PSID="3EF8DFC522EDF1b895-4666-a9d2-026b0a4716c9";AttackSequence="0";AttackParamDesc="";AttackParamIndex="0";AttackParamS

X-RequestManager-Memo: sc="1";rid="b730a5cf";
X-Request-Memo: rid="1f31fe2e";sc="1";thid="72";
Cookie: credit_dossier_session=d0eAPzIRp8QdGNrD2brN1Zr7r0-kEWvBBheaS1R6PKtDjB05Ngdyitb3WcLSs1uU;CustomCookie=WebInspect209950ZXFA7CF6531B4

Sec-Ch-Ua-Platform: "Windows"
Accept-Language: en-US,en;q=0.9
Sec-Ch-Ua: "Not;A=Brand";v="8", "Chromium";v="150"
Content-Type: application/json
Sec-Ch-Ua-Mobile: ?0
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/150.0.0.0 Safari/537.36
Accept: */*
Origin: http://webinspect.microfocus.com
Sec-Fetch-Site: same-origin
Sec-Fetch-Mode: cors
Sec-Fetch-Dest: empty
Accept-Encoding: gzip, deflate
Priority: u=1, i

© Copyright 2008-2026 Open Text.

HTML5: CORS Unsafe Methods Allowed	Low

URL: https://credit-dossier-ip-safe.up.railway.app:443/api/deals/deal_9bf5309/sections/deal_9bf5309_relationship_summary/edit-lock

https://credit-dossier-ip-safe.up.railway.app:443/api/deals/deal_9bf5309/sections/deal_9bf5309_relationship_summary/edit-lock (HTML5: CORS Unsafe Methods Allowed)	Low

Response

...TRUNCATED...nguage, Content-Language, Content-Type
access-control-allow-methods: GET, HEAD, POST, PATCH, DELETE, OPTIONS
access-control-max-age: 600
Content-Typ...TRUNCATED...

URL: https://credit-dossier-ip-safe.up.railway.app:443/api/deals/deal_9bf5309/theme/

https://credit-dossier-ip-safe.up.railway.app:443/api/deals/deal_9bf5309/theme/ (HTML5: CORS Unsafe Methods Allowed)	Low

Issue Details

Kingdom: Encapsulation
Scan Engine: WEBINSPECT (Dynamic Analysis)
CWE: CWE ID 749

Request

OPTIONS /api/deals/deal_9bf5309/theme/?NYqrLb%20J*Mmkz!8o1!/%**M HTTP/1.1
Referer: https://credit-dossier-ip-safe.up.railway.app/api/deals/deal_9bf5309/theme/extract
Accept: */*
Pragma: no-cache
Accept-Encoding: gzip, deflate
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:130.0) Gecko/20100101 Firefox/130.0
Host: credit-dossier-ip-safe.up.railway.app
Access-Control-Request-Method: POST
Access-Control-Request-Headers: X-Pingsession
Origin: http://webinspect.microfocus.com
Connection: Keep-Alive
X-WIPP: AscVersion=26.2.0.55
X-Scan-Memo:
Category="Audit.Attack";SID="13E23C1F0D5F3F8369DEA66F35295A9C";PSID="8C9231852702C49
b895-4666-
a9d2-026b0a4716c9";AttackSequence="0";AttackParamDesc="";AttackParamIndex="0";AttackParamS

X-RequestManager-Memo: sc="1";rid="5ed19199";
X-Request-Memo: rid="47dc90e6";sc="1";thid="72";
Cookie: CustomCookie=WebInspect209950ZXFA7CF6531B49486793E4B5D01CE6C4F4Y9EB5

Response

...TRUNCATED...nguage, Content-Language, Content-Type
access-control-allow-methods: GET, HEAD, POST, PATCH, DELETE, OPTIONS
access-control-max-age: 600
Content-Typ...TRUNCATED...

© Copyright 2008-2026 Open Text.

HTML5: CORS Unsafe Methods Allowed	Low

URL: https://credit-dossier-ip-safe.up.railway.app:443/api/deals/deal_9bf5309/theme/)LQJ4@b/TBA8]ZbIJ5qg

https://credit-dossier-ip-safe.up.railway.app:443/api/deals/deal_9bf5309/theme/)LQJ4@b/TBA8]ZbIJ5qg (HTML5: CORS Unsafe Methods Allowed)	Low

Issue Details

Kingdom: Encapsulation
Scan Engine: WEBINSPECT (Dynamic Analysis)
CWE: CWE ID 749

Request

```
OPTIONS /api/deals/deal_9bf5309/theme/)LQJ4@b/TBA8]ZbIJ5qg?*/k HTTP/1.1
Referer: https://credit-dossier-ip-safe.up.railway.app/api/deals/deal_9bf5309/theme/extract
Accept: */*
Pragma: no-cache
Accept-Encoding: gzip, deflate
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:130.0) Gecko/20100101 Firefox/130.0
Host: credit-dossier-ip-safe.up.railway.app
Access-Control-Request-Method: POST
Access-Control-Request-Headers: X-Pingsession
Origin: http://webinspect.microfocus.com
Connection: Keep-Alive
X-WIPP: AscVersion=26.2.0.55
X-Scan-Memo:
Category="Audit.Attack";SID="AAB2CDDA9AF3BE3D498544AA2F904D0D";PSID="B9B0EEC6681A68
b895-4666-
a9d2-026b0a4716c9";AttackSequence="0";AttackParamDesc="";AttackParamIndex="0";AttackParamS

X-RequestManager-Memo: sc="1";rid="b3188f45";
X-Request-Memo: rid="ed1cfae1";sc="1";thid="86";
Cookie: CustomCookie=WebInspect209950ZXFA7CF6531B49486793E4B5D01CE6C4F4Y9EB5
```

Response

```
...TRUNCATED...nguage, Content-Language, Content-Type
access-control-allow-methods: GET, HEAD, POST, PATCH, DELETE, OPTIONS
access-control-max-age: 600
Content-Typ...TRUNCATED...
```

URL: https://credit-dossier-ip-safe.up.railway.app:443/api/deals/deal_9bf5309/versions

https://credit-dossier-ip-safe.up.railway.app:443/api/deals/deal_9bf5309/versions (HTML5: CORS Unsafe Methods Allowed)	Low

Issue Details

Kingdom: Encapsulation
Scan Engine: WEBINSPECT (Dynamic Analysis)
CWE: CWE ID 749

Request

```
OPTIONS /api/deals/deal_9bf5309/versions HTTP/1.1
Host: credit-dossier-ip-safe.up.railway.app
```


© Copyright 2008-2026 Open Text.

HTML5: CORS Unsafe Methods Allowed	Low

URL: https://credit-dossier-ip-safe.up.railway.app:443/api/deals/deal_9bf5309/versions

https://credit-dossier-ip-safe.up.railway.app:443/api/deals/deal_9bf5309/versions (HTML5: CORS Unsafe Methods Allowed)	Low

Pragma: no-cache
Access-Control-Request-Method: POST
Access-Control-Request-Headers: X-Pingsession
Referer: https://credit-dossier-ip-safe.up.railway.app/api/deals/deal_9bf5309/versions
Connection: Keep-Alive
Content-Length: 1683
X-WIPP: AscVersion=26.2.0.55
X-Scan-Memo:
Category="Audit.Attack";SID="08FD6540B3BD43E278011D186629E96A";PSID="D54D6B8E6FEF430b895-4666-
a9d2-026b0a4716c9";AttackSequence="0";AttackParamDesc="";AttackParamIndex="0";AttackParamS

X-RequestManager-Memo: sc="1";rid="d2a14eba";
X-Request-Memo: rid="9ff1864f";sc="1";thid="114";
Cookie: credit_dossier_session=DOCIYsfqpz7xbUnjBDXZg1m4803-7iA7L8FrxLsMUtfUb3-
FJ4C2ntsn6ovP8Mqg;CustomCookie=WebInspect209950ZXFA7CF6531B49486793E4B5D01CE6C4F

Sec-Ch-Ua-Platform: "Windows"
Accept-Language: en-US,en;q=0.9
Sec-Ch-Ua: "Not;A=Brand";v="8", "Chromium";v="150"
Content-Type: application/json
Sec-Ch-Ua-Mobile: ?0
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko)
Chrome/150.0.0.0 Safari/537.36
Accept: */*
Origin: http://webinspect.microfocus.com
Sec-Fetch-Site: same-origin
Sec-Fetch-Mode: cors
Sec-Fetch-Dest: empty
Accept-Encoding: gzip, deflate
Priority: u=1, i

{"notes":"// Basic payload\n<script>alert('XSS')</script>\n<scr<script>ipt>alert('XSS')</
scr<script>ipt>\n\"><script>alert('XSS')</script>\n\"><script>alert(String.fromCharCode(88,83,83))</
script>\n<script>\\u0061lert('22')</script>\n<script>eval('\\x61lert(\\'33\\')')</
script>\n<script>eval(8680439..toString(30))(983801..toString(36))</script> //parseInt(\"confirm\",30)
== 8680439 && 8680439..toString(30) == \"confirm\"\n<object/
data=\"javascript:alert(23)\...TRUNCATED...

Response

...TRUNCATED...nguage, Content-Language, Content-Type
access-control-allow-methods: GET, HEAD, POST, PATCH, DELETE, OPTIONS
access-control-max-age: 600
Content-Typ...TRUNCATED...

© Copyright 2008-2026 Open Text.

HTML5: CORS Unsafe Methods Allowed — Low

URL: https://credit-dossier-ip-safe.up.railway.app:443/api/deals/deal_9bf5309/versions/

https://credit-dossier-ip-safe.up.railway.app:443/api/deals/deal_9bf5309/versions/ (HTML5: CORS Unsafe Methods Allowed) — Low

Issue Details

Kingdom: Encapsulation
Scan Engine: WEBINSPECT (Dynamic Analysis)
CWE: CWE ID 749

Request

```
OPTIONS /api/deals/deal_9bf5309/versions/ HTTP/1.1
Referer: https://credit-dossier-ip-safe.up.railway.app/api/deals/deal_9bf5309/versions/v_0b2882/
download
Accept: */*
Pragma: no-cache
Accept-Encoding: gzip, deflate
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:130.0) Gecko/20100101 Firefox/130.0
Host: credit-dossier-ip-safe.up.railway.app
Access-Control-Request-Method: POST
Access-Control-Request-Headers: X-Pingsession
Origin: http://webinspect.microfocus.com
Connection: Keep-Alive
X-WIPP: AscVersion=26.2.0.55
X-Scan-Memo:
Category="Audit.Attack";SID="BAFB7F402BC5609EF45FF826B29343AB";PSID="76B007786BE2B5D
b895-4666-
a9d2-026b0a4716c9";AttackSequence="0";AttackParamDesc="";AttackParamIndex="0";AttackParamS

X-RequestManager-Memo: sc="1";rid="86e836bb";
X-Request-Memo: rid="a4cf3361";sc="1";thid="114";
Cookie: CustomCookie=WebInspect209950ZXFA7CF6531B49486793E4B5D01CE6C4F4Y9EB5
```

Response

```
...TRUNCATED...nguage, Content-Language, Content-Type
access-control-allow-methods: GET, HEAD, POST, PATCH, DELETE, OPTIONS
access-control-max-age: 600
Content-Typ...TRUNCATED...
```

URL: https://credit-dossier-ip-safe.up.railway.app:443/api/deals/deal_9bf5309/versions/v_0b2882/download

https://credit-dossier-ip-safe.up.railway.app:443/api/deals/deal_9bf5309/versions/v_0b2882/download (HTML5: CORS Unsafe Methods Allowed) — Low

Issue Details

Kingdom: Encapsulation
Scan Engine: WEBINSPECT (Dynamic Analysis)
CWE: CWE ID 749

Request

```
OPTIONS /api/deals/deal_9bf5309/versions/v_0b2882/download HTTP/1.1
```


© Copyright 2008-2026 Open Text.

HTML5: CORS Unsafe Methods Allowed	Low

URL: https://credit-dossier-ip-safe.up.railway.app:443/api/deals/deal_9bf5309/versions/v_0b2882/download

https://credit-dossier-ip-safe.up.railway.app:443/api/deals/deal_9bf5309/versions/v_0b2882/download (HTML5: CORS Unsafe Methods Allowed)	Low

Host: credit-dossier-ip-safe.up.railway.app
Pragma: no-cache
Access-Control-Request-Method: POST
Access-Control-Request-Headers: X-Pingsession
Referer: https://credit-dossier-ip-safe.up.railway.app/api/deals/deal_9bf5309/versions/v_0b2882/download
Connection: Keep-Alive
X-WIPP: AscVersion=26.2.0.55
X-Scan-Memo: Category="Audit.Attack";SID="3204C2D78B98F7C54581491CBDAC988D";PSID="02FF21F599BAC43b895-4666-a9d2-026b0a4716c9";AttackSequence="0";AttackParamDesc="";AttackParamIndex="0";AttackParamS

X-RequestManager-Memo: sc="1";rid="20066601";
X-Request-Memo: rid="33380200";sc="1";thid="72";
Cookie: credit_dossier_session=DOCIYsfqpz7xbUnjBDXZg1m4803-7iA7L8FrxLsMUtfUb3-FJ4C2ntsn6ovP8Mqg;CustomCookie=WebInspect209950ZXFA7CF6531B49486793E4B5D01CE6C4F

Sec-Ch-Ua-Platform: "Windows"
Accept-Language: en-US,en;q=0.9
Sec-Ch-Ua: "Not;A=Brand";v="8", "Chromium";v="150"
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/150.0.0.0 Safari/537.36
Sec-Ch-Ua-Mobile: ?0
Accept: */*
Origin: http://webinspect.microfocus.com
Sec-Fetch-Site: same-origin
Sec-Fetch-Mode: cors
Sec-Fetch-Dest: empty
Accept-Encoding: gzip, deflate
Priority: u=1, i

Response

...TRUNCATED...nguage, Content-Language, Content-Type
access-control-allow-methods: GET, HEAD, POST, PATCH, DELETE, OPTIONS
access-control-max-age: 600
Content-Typ...TRUNCATED...

HTML5: Misconfigured Content Security Policy	Low

URL: https://credit-dossier-ip-safe.up.railway.app:443/

https://credit-dossier-ip-safe.up.railway.app:443/ (HTML5: Misconfigured Content Security Policy)	Low

Issue Details

Kingdom: Encapsulation
Scan Engine: WEBINSPECT (Dynamic Analysis)

© Copyright 2008-2026 Open Text.

HTML5: Misconfigured Content Security Policy	Low
URL: https://credit-dossier-ip-safe.up.railway.app:443/	
https://credit-dossier-ip-safe.up.railway.app:443/ (HTML5: Misconfigured Content Security Policy)	Low

CWE: CWE ID 942, CWE ID 1173

Request

```
GET / HTTP/1.1
Host: credit-dossier-ip-safe.up.railway.app
Sec-Ch-Ua: "Not;A=Brand";v="8", "Chromium";v="150"
Sec-Ch-Ua-Mobile: ?0
Sec-Ch-Ua-Platform: "Windows"
Accept-Language: en-US,en;q=0.9
Upgrade-Insecure-Requests: 1
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko)
Chrome/150.0.0.0 Safari/537.36
Accept: */*
Sec-Fetch-Site: none
Sec-Fetch-Mode: navigate
Sec-Fetch-User: ?1
Sec-Fetch-Dest: document
Accept-Encoding: gzip, deflate
Priority: u=0, i
Pragma: no-cache
Connection: Keep-Alive
X-WIPP: AscVersion=26.2.0.55
X-RequestManager-Memo:
Category="TrafficMacro.NamedMacro";MacroName="WebProxyGenerated";trid="48ea27e4";stid="109

X-Scan-Memo:
Category="Macro";SID="3762DE85075728E77DD5CE6431933650";SessionType="NamedMacro";Cra

X-Request-Memo: rid="b13ee80e";sc="1";thid="128";
Cookie: CustomCookie=WebInspect209950ZXFA7CF6531B49486793E4B5D01CE6C4F4Y9EB5
```

Response

```
...TRUNCATED...TP/1.1 200 OK
content-security-policy: default-src 'self'; base-uri 'self'; object-src 'none'; frame-ancestors
'none'; form-action 'self'; script-src 'self' 'unsafe-inline'; style-src 'self' 'unsafe-inline'; img-src
'self' data: blob:; font-src 'self' data:; connect-src 'self'
Content-Type: text/html; charset=utf-8...TRUNCATED...
```

Insecure Transport: HSTS not Set	Low
URL: https://credit-dossier-ip-safe.up.railway.app:443/assets/jsx-runtime-D3jfb0Ew.js	
https://credit-dossier-ip-safe.up.railway.app:443/assets/jsx-runtime-D3jfb0Ew.js (Insecure Transport: HSTS not Set)	Low

Issue Details

Kingdom: Security Features
Scan Engine: WEBINSPECT (Dynamic Analysis)

© Copyright 2008-2026 Open Text.

Insecure Transport: HSTS not Set	Low
URL: https://credit-dossier-ip-safe.up.railway.app:443/assets/jsx-runtime-D3jfb0Ew.js	
https://credit-dossier-ip-safe.up.railway.app:443/assets/jsx-runtime-D3jfb0Ew.js (Insecure Transport: HSTS not Set)	Low

CWE: CWE ID 319

Request

```
GET /assets/jsx-runtime-D3jfb0Ew.js HTTP/1.1
Referer: https://credit-dossier-ip-safe.up.railway.app:443/
Host: credit-dossier-ip-safe.up.railway.app
Accept: */*
Accept-Language: en-US,en;q=0.5
Accept-Encoding: gzip, deflate
Sec-Fetch-Dest: script
Sec-Fetch-Mode: cors
Sec-Fetch-Site: same-origin
Priority: u=1
Pragma: no-cache
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:130.0) Gecko/20100101 Firefox/130.0
Connection: Keep-Alive
X-WIPP: AscVersion=26.2.0.55
X-Scan-Memo:
ScriptEngine="Gecko";Category="Crawl";SID="C34423E0F5D7EE696D50D7294E60A4DE";PSID="376

X-RequestManager-Memo: stid="109";stmi="0";sc="1";rid="14efc5ad";
X-Request-Memo: rid="5c39c924";sc="1";thid="159";
Cookie: CustomCookie=WebInspect209950ZXFA7CF6531B49486793E4B5D01CE6C4F4Y9EB5
```

Response

```
HTTP/1.1 200 OK
Cache-Control: public, max-age=31536000, immutable
Content-Type: application/javascript; charset=utf-8
Date: Tue, 06 Oct 2026 07:16:11 GMT
Server: railway-hikari
x-railway-request-id: AOAqG1ahSqSyknyk9o6EoQ
x-hikari-trace: sin1.nzn2
x-railway-edge: sin1
Connection: keep-alive
Content-Length: 8901

var
e=Object.create,t=Object.defineProperty,n=Object.getOwnPropertyDescriptor,r=Object.getOwnPropert
(e((t={exports:{}}).exports,t),e=null),t.exports),s=(e,n)=>{let r={};for(var i in e)t(r,i,{get:e[i],enumerable:!
0});return n||t(r,Symbol.toStringTag,{value:`Module`}),r},c=(e,i,o,s)=>{if(i&&typeof i==`object`||typeof
i==`function`)for(var c=r(i),l=0,u=c.length,d;l<u;l++)d=c[l],!a.call(e,d)&&d!==o&&t(e,d,{get:
(e=>i[e]).bind(null,d),enumerable:!(s=n(i,d))||s.enumerable});return e},l=(n,r,o)=>(o=n==null?
{}:e(i(n)),c(r||!n||!n.__esModule||!a.call(n,`default`)?t(o,`default`,{value:n,enumerable:!
0}):o,n)),u=o((e=>{var
t=Symbol.for(`react.transitional.element`),n=Symbol.for(`react.portal`),r=Symbol.for(`react.fragment`),i=
h(e){return typeof e!=`object`||!e?null:(e=m&&e[m]||e[`@@iterator`],typeof e==`function`?e:null)}var
g={isMounted:function(){return!1},enqueueForceUpdate:function(){},enqueueReplaceState:function()
{},enqueueSetState:function(){}},_=Object.assign,v={};function y(e,t,n)
```


© Copyright 2008-2026 Open Text.

Insecure Transport: HSTS not Set	Low
URL: https://credit-dossier-ip-safe.up.railway.app:443/assets/jsx-runtime-D3jfb0Ew.js	
https://credit-dossier-ip-safe.up.railway.app:443/assets/jsx-runtime-D3jfb0Ew.js (Insecure Transport: HSTS not Set)	Low

{this.props=e,this.context=t,this.refs=v,this.updater=n||g}
y.prototype.isReactComponent={},y.prototype.setState=function(e,t){if(typeof e!=`object`&&typeof e!
=`function`&&e!=null)throw Error(`takes an object of state variables to update or a function which
retur...TRUNCATED...

Often Misused: File Upload	Low
URL: https://credit-dossier-ip-safe.up.railway.app:443/api/deals/deal_9bf5309/sections/deal_9bf5309_executive_summary/template	
https://credit-dossier-ip-safe.up.railway.app:443/api/deals/deal_9bf5309/sections/deal_9bf5309_executive_summary/template (Often Misused: File Upload)	Low

Issue Details

Kingdom: API Abuse
Scan Engine: WEBINSPECT (Dynamic Analysis)
CWE: CWE ID 434

Request

POST /api/deals/deal_9bf5309/sections/deal_9bf5309_executive_summary/template HTTP/1.1
Host: credit-dossier-ip-safe.up.railway.app
Pragma: no-cache
Connection: Keep-Alive
X-WIPP: AscVersion=26.2.0.55
X-RequestManager-Memo:
Category="TrafficMacro.NamedMacro";MacroName="WebProxyGenerated";trid="48ea27e4";stid="109

X-Scan-Memo:
Category="Macro";SID="68F445ACF96D486FEB55E54F3F12E0B4";PSID="95248F622E924ADA2EC

X-Request-Memo: rid="c192e60f";sc="1";thid="128";
Cookie: credit_dossier_session=DOCIYsfqpz7xbUnjBDXZg1m4803-7iA7L8FrxLsMUtfUb3-
FJ4C2ntsn6ovP8Mqg;CustomCookie=WebInspect209950ZXFA7CF6531B49486793E4B5D01CE6C4F

Content-Length: 67198
Sec-Ch-Ua-Platform: "Windows"
Accept-Language: en-US,en;q=0.9
Sec-Ch-Ua: "Not;A=Brand";v="8", "Chromium";v="150"
Content-Type: multipart/form-data; boundary=----WebKitFormBoundaryxnH0TCMG2yBIvsSS
Sec-Ch-Ua-Mobile: ?0
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko)
Chrome/150.0.0.0 Safari/537.36
Accept: */*
Origin: https://credit-dossier-ip-safe.up.railway.app
Sec-Fetch-Site: same-origin
Sec-Fetch-Mode: cors
Sec-Fetch-Dest: empty
Accept-Encoding: gzip, deflate
Priority: u=1, i

© Copyright 2008-2026 Open Text.

Often Misused: File Upload — Low

URL: https://credit-dossier-ip-safe.up.railway.app:443/api/deals/deal_9bf5309/sections/deal_9bf5309_executive_summary/template

https://credit-dossier-ip-safe.up.railway.app:443/api/deals/deal_9bf5309/sections/deal_9bf5309_executive_summary/template (Often Misused: File Upload) — **Low**

```
------WebKitFormBoundaryxnH0TCMG2yBIvsSS
Content-Disposition: form-data; name="file"; filename="CVE_Assessment_Python311.docx"
Content-Type: application/vnd.openxmlformats-officedocument.wordprocessingml.document

PK������uE]ï¿½Rï¿½ï¿½ï¿½ï¿½ï¿½[Content_Types].xmlï¿½ï¿½=oï¿½0ï¿½ï¿½ï¿½ï¿½
Aï¿½ï¿½@ï¿½Ó¡
ï¿½ï¿½16ï¿½]ïï¿½$ï¿½%ï¿½ï¿½ï¿½ï¿½ï¿½>ï¿½ï¿½Eï¿½D ï¿½,\ï¿½ï¿½ï¿½ï¿½>
q~ï¿½;ï¿½m ï¿½ï¿½X ï¿½Õ¬ï¿½ï¿½ï¿½ï¿½Ûºï¿½ï¿½ï¿½ï¿½-/ï¿½ï¿½Xï¿½ï¿½ï¿½ï¿½#ï¿½ï¿½ï¿½ï¿½ï¿½|
ï¿½/ï¿½(ï¿½Eï¿½ï¿½9|ï¿½T NRï¿½ï¿½`ï¿½lã£“Lï¿½ï¿½ï¿½ï¿½Rï¿½ï¿½-
ï¿½ï¿½ï¿½ï¿½7ï¿½<2 ï¿½ï¿½ï¿½ï¿½b~ ï¿½\[ï¿½nz  Dï¿½ï¿½ï¿½<ï¿½zÚ¯ï¿½ï¿½Ü¸
bo&ï¿½ï¿½ï¿½...TRUNCATED...
```

Response

```
HTTP/1.1 400 Bad Request
access-control-allow-credentials: true
access-control-expose-headers: Content-Disposition
content-security-policy: default-src 'none'; base-uri 'none'; form-action 'none'; frame-ancestors 'none';
object-src 'none'
Content-Type: application/json
Date: Tue, 06 Oct 2026 07:23:58 GMT
permissions-policy: camera=(), microphone=(), geolocation=(), payment=(), usb=()
referrer-policy: no-referrer
Server: railway-hikari
vary: Origin
x-content-type-options: nosniff
x-frame-options: DENY
x-railway-request-id: tYytSITQRVSO62JEnPRhug
Content-Length: 131
x-hikari-trace: sin1.tr00
x-railway-edge: sin1
Connection: keep-alive

{"error_code":"FILE-001","detail":"The uploaded file is invalid or
unsupported.","event_id":"b57a91d2-7b51-4979-8f78-f295d05081ec"}
```

Often Misused: Weak SSL Certificate — Low

URL: https://credit-dossier-ip-safe.up.railway.app:443/assets/search-Dx8hvHZn.js

https://credit-dossier-ip-safe.up.railway.app:443/assets/search-Dx8hvHZn.js (Often Misused: Weak SSL Certificate) — **Low**

Issue Details

Kingdom: API Abuse
Scan Engine: WEBINSPECT (Dynamic Analysis)
CWE: CWE ID 296

Request

```
GET /assets/search-Dx8hvHZn.js HTTP/1.1
```


© Copyright 2008-2026 Open Text.

Often Misused: Weak SSL Certificate	Low

URL: https://credit-dossier-ip-safe.up.railway.app:443/assets/search-Dx8hvHZn.js

https://credit-dossier-ip-safe.up.railway.app:443/assets/search-Dx8hvHZn.js (Often Misused: Weak SSL Certificate)	Low

Referer: https://credit-dossier-ip-safe.up.railway.app:443/
Host: credit-dossier-ip-safe.up.railway.app
Accept: */*
Accept-Language: en-US,en;q=0.5
Accept-Encoding: gzip, deflate
Sec-Fetch-Dest: script
Sec-Fetch-Mode: cors
Sec-Fetch-Site: same-origin
Priority: u=1
Pragma: no-cache
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:130.0) Gecko/20100101 Firefox/130.0
Connection: Keep-Alive
X-WIPP: AscVersion=26.2.0.55
X-Scan-Memo:
ScriptEngine="Gecko";Category="Crawl";SID="5AA9FD8041D0F21C4D9429BF226F7F44";PSID="376

X-RequestManager-Memo: stid="109";stmi="0";sc="1";rid="edae89a4";
X-Request-Memo: rid="af47fe42";sc="1";thid="152";
Cookie: CustomCookie=WebInspect209950ZXFA7CF6531B49486793E4B5D01CE6C4F4Y9EB5

Response

HTTP/1.1 200 OK
Cache-Control: public, max-age=31536000, immutable
Content-Type: application/javascript; charset=utf-8
Date: Tue, 06 Oct 2026 07:16:11 GMT
Server: railway-hikari
x-railway-request-id: t266G9ToSEOOEPaJxtoGcA
x-hikari-trace: sin1.hs0s
x-railway-edge: sin1
Connection: keep-alive
Content-Length: 163

import{p as e}from"./index-BHMdI9Xr.js";var t=e(`search`,[[`path`,{d:`m21 21-4.34-4.34`,key:`14j7rj`}],[`circle`,{cx:`11`,cy:`11`,r:`8`,key:`4ej97u`}]]);export{t};

Web Server Misconfiguration: Insecure Content-Type Setting	Low

URL: https://credit-dossier-ip-safe.up.railway.app:443/api/auth/account-status

https://credit-dossier-ip-safe.up.railway.app:443/api/auth/account-status (Web Server Misconfiguration: Insecure Content-Type Setting)	Low

Issue Details

Kingdom: Environment
Scan Engine: WEBINSPECT (Dynamic Analysis)
CWE: CWE ID 79, CWE ID 116

Request

POST /api/auth/account-status HTTP/1.1
Host: credit-dossier-ip-safe.up.railway.app

© Copyright 2008-2026 Open Text.

Web Server Misconfiguration: Insecure Content-Type Setting	Low

URL: https://credit-dossier-ip-safe.up.railway.app:443/api/auth/account-status

https://credit-dossier-ip-safe.up.railway.app:443/api/auth/account-status (Web Server Misconfiguration: Insecure Content-Type Setting)	Low

Pragma: no-cache
Connection: Keep-Alive
Content-Length: 18
Sec-Ch-Ua-Platform: "Windows"
Accept-Language: en-US,en;q=0.9
Sec-Ch-Ua: "Not;A=Brand";v="8", "Chromium";v="150"
Content-Type: application/json
Sec-Ch-Ua-Mobile: ?0
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/150.0.0.0 Safari/537.36
Accept: */*
Origin: https://credit-dossier-ip-safe.up.railway.app
Sec-Fetch-Site: same-origin
Sec-Fetch-Mode: cors
Sec-Fetch-Dest: empty
Accept-Encoding: gzip, deflate
Priority: u=1, i
X-WIPP: AscVersion=26.2.0.55
X-RequestManager-Memo:
Category="TrafficMacro.NamedMacro";MacroName="WebProxyGenerated";trid="48ea27e4";stid="109

X-Scan-Memo:
Category="Macro";SID="8B10FDDCE1E53A43A5202D43A8A0E66D";PSID="A1C158CCB1DAE3BF96

X-Request-Memo: rid="49c160f9";sc="1";thid="128";
Cookie: CustomCookie=WebInspect209950ZXFA7CF6531B49486793E4B5D01CE6C4F4Y9EB5

{"user_id":"rela"}

Response

...TRUNCATED...none'; object-src 'none'
Content-Type: application/json
Date: Tue, 06 Oct 2026 07:16:27 GMT
p...TRUNCATED...

URL: https://credit-dossier-ip-safe.up.railway.app:443/api/auth/configuration

https://credit-dossier-ip-safe.up.railway.app:443/api/auth/configuration (Web Server Misconfiguration: Insecure Content-Type Setting)	Low

Issue Details

Kingdom: Environment
Scan Engine: WEBINSPECT (Dynamic Analysis)
CWE: CWE ID 79, CWE ID 116

Request

GET /api/auth/configuration HTTP/1.1
Host: credit-dossier-ip-safe.up.railway.app
Pragma: no-cache

© Copyright 2008-2026 Open Text.

Web Server Misconfiguration: Insecure Content-Type Setting	Low

URL: https://credit-dossier-ip-safe.up.railway.app:443/api/auth/configuration

https://credit-dossier-ip-safe.up.railway.app:443/api/auth/configuration (Web Server Misconfiguration: Insecure Content-Type Setting)	Low

Connection: Keep-Alive
Sec-Ch-Ua-Platform: "Windows"
Accept-Language: en-US,en;q=0.9
Sec-Ch-Ua: "Not;A=Brand";v="8", "Chromium";v="150"
Content-Type: application/json
Sec-Ch-Ua-Mobile: ?0
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/150.0.0.0 Safari/537.36
Accept: */*
Sec-Fetch-Site: same-origin
Sec-Fetch-Mode: cors
Sec-Fetch-Dest: empty
Accept-Encoding: gzip, deflate
Priority: u=1, i
X-WIPP: AscVersion=26.2.0.55
X-RequestManager-Memo:
Category="TrafficMacro.NamedMacro";MacroName="WebProxyGenerated";trid="48ea27e4";stid="109'

X-Scan-Memo:
Category="Macro";SID="A1C158CCB1DAE3BF96391BE2E5A035B6";PSID="C2356D179DFDD9584C

X-Request-Memo: rid="035cc07d";sc="1";thid="128";
Cookie: CustomCookie=WebInspect209950ZXFA7CF6531B49486793E4B5D01CE6C4F4Y9EB5

Response

...TRUNCATED...none'; object-src 'none'
Content-Type: **application/json**
Date: Tue, 06 Oct 2026 07:16:25 GMT
p...TRUNCATED...

URL: https://credit-dossier-ip-safe.up.railway.app:443/api/auth/login

https://credit-dossier-ip-safe.up.railway.app:443/api/auth/login (Web Server Misconfiguration: Insecure Content-Type Setting)	Low

Issue Details

Kingdom: Environment
Scan Engine: WEBINSPECT (Dynamic Analysis)
CWE: CWE ID 79, CWE ID 116

Request

POST /api/auth/login HTTP/1.1
Host: credit-dossier-ip-safe.up.railway.app
Pragma: no-cache
Connection: Keep-Alive
Content-Length: 52
Sec-Ch-Ua-Platform: "Windows"
Accept-Language: en-US,en;q=0.9

© Copyright 2008-2026 Open Text.

Web Server Misconfiguration: Insecure Content-Type Setting	Low

URL: https://credit-dossier-ip-safe.up.railway.app:443/api/auth/login

https://credit-dossier-ip-safe.up.railway.app:443/api/auth/login (Web Server Misconfiguration: Insecure Content-Type Setting)	Low

Sec-Ch-Ua: "Not;A=Brand";v="8", "Chromium";v="150"
Content-Type: application/json
Sec-Ch-Ua-Mobile: ?0
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/150.0.0.0 Safari/537.36
Accept: */*
Origin: https://credit-dossier-ip-safe.up.railway.app
Sec-Fetch-Site: same-origin
Sec-Fetch-Mode: cors
Sec-Fetch-Dest: empty
Accept-Encoding: gzip, deflate
Priority: u=1, i
X-WIPP: AscVersion=26.2.0.55
X-RequestManager-Memo:
Category="TrafficMacro.NamedMacro";MacroName="WebProxyGenerated";trid="48ea27e4";stid="109

X-Scan-Memo:
Category="Macro";SID="214D6F2AC536737C97F77581CEEA65B6";PSID="BDEC4B8D4835A2FA6F8

X-Request-Memo: rid="6bb3e9a5";sc="1";thid="128";
Cookie: CustomCookie=WebInspect209950ZXFA7CF6531B49486793E4B5D01CE6C4F4Y9EB5

{"user_id":"relation","password":"Creditpolicy@123"}

Response

...TRUNCATED...none'; object-src 'none'
Content-Type: **application/json**
Date: Tue, 06 Oct 2026 07:16:33 GMT
p...TRUNCATED...

URL: https://credit-dossier-ip-safe.up.railway.app:443/api/companies

https://credit-dossier-ip-safe.up.railway.app:443/api/companies (Web Server Misconfiguration: Insecure Content-Type Setting)	Low

Issue Details

Kingdom: Environment
Scan Engine: WEBINSPECT (Dynamic Analysis)
CWE: CWE ID 79, CWE ID 116

Request

GET /api/companies HTTP/1.1
Host: credit-dossier-ip-safe.up.railway.app
Pragma: no-cache
Connection: Keep-Alive
X-WIPP: AscVersion=26.2.0.55
X-RequestManager-Memo:
Category="TrafficMacro.NamedMacro";MacroName="WebProxyGenerated";trid="48ea27e4";stid="109

© Copyright 2008-2026 Open Text.

Web Server Misconfiguration: Insecure Content-Type Setting	Low

URL: https://credit-dossier-ip-safe.up.railway.app:443/api/companies

https://credit-dossier-ip-safe.up.railway.app:443/api/companies (Web Server Misconfiguration: Insecure Content-Type Setting)	Low

X-Scan-Memo:
Category="Macro";SID="A14780F0C20E328067704E97E88359CC";PSID="D12ED0ECAF32AAAC069

X-Request-Memo: rid="415957a9";sc="1";thid="128";
Cookie: credit_dossier_session=d0eAPzIRp8QdGNrD2brN1Zr7r0-kEWvBBheaS1R6PKtDjB05Ngdyitb3WcLSs1uU;CustomCookie=WebInspect209950ZXFA7CF6531B49

Sec-Ch-Ua-Platform: "Windows"
Accept-Language: en-US,en;q=0.9
Sec-Ch-Ua: "Not;A=Brand";v="8", "Chromium";v="150"
Content-Type: application/json
Sec-Ch-Ua-Mobile: ?0
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/150.0.0.0 Safari/537.36
Accept: */*
Sec-Fetch-Site: same-origin
Sec-Fetch-Mode: cors
Sec-Fetch-Dest: empty
Accept-Encoding: gzip, deflate
Priority: u=1, i

Response

...TRUNCATED...none'; object-src 'none'
Content-Type: application/json
Date: Tue, 06 Oct 2026 07:16:58 GMT
p...TRUNCATED...

URL: https://credit-dossier-ip-safe.up.railway.app:443/api/companies/Creditprime/details

https://credit-dossier-ip-safe.up.railway.app:443/api/companies/Creditprime/details (Web Server Misconfiguration: Insecure Content-Type Setting)	Low

Issue Details

Kingdom: Environment
Scan Engine: WEBINSPECT (Dynamic Analysis)
CWE: CWE ID 79, CWE ID 116

Request

GET /api/companies/Creditprime/details HTTP/1.1
Host: credit-dossier-ip-safe.up.railway.app
Pragma: no-cache
Connection: Keep-Alive
X-WIPP: AscVersion=26.2.0.55
X-RequestManager-Memo:
Category="TrafficMacro.NamedMacro";MacroName="WebProxyGenerated";trid="48ea27e4";stid="109

X-Scan-Memo:
Category="Macro";SID="7D0FC3494ACA7F6335963A4BF68FD292";PSID="93F6D637D4AA2471278

© Copyright 2008-2026 Open Text.

Web Server Misconfiguration: Insecure Content-Type Setting	Low

URL: https://credit-dossier-ip-safe.up.railway.app:443/api/companies/Creditprime/details

https://credit-dossier-ip-safe.up.railway.app:443/api/companies/Creditprime/details (Web Server Misconfiguration: Insecure Content-Type Setting)	Low

X-Request-Memo: rid="014f1743";sc="1";thid="128";
Cookie: credit_dossier_session=DOCIYsfqpz7xbUnjBDXZg1m4803-7iA7L8FrxLsMUtfUb3-FJ4C2ntsn6ovP8Mqg;CustomCookie=WebInspect209950ZXFA7CF6531B49486793E4B5D01CE6C4F

Sec-Ch-Ua-Platform: "Windows"
Accept-Language: en-US,en;q=0.9
Sec-Ch-Ua: "Not;A=Brand";v="8", "Chromium";v="150"
Content-Type: application/json
Sec-Ch-Ua-Mobile: ?0
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/150.0.0.0 Safari/537.36
Accept: */*
Sec-Fetch-Site: same-origin
Sec-Fetch-Mode: cors
Sec-Fetch-Dest: empty
Accept-Encoding: gzip, deflate
Priority: u=1, i

Response

...TRUNCATED...none'; object-src 'none'
Content-Type: application/json
Date: Tue, 06 Oct 2026 07:27:41 GMT
p...TRUNCATED...

URL: https://credit-dossier-ip-safe.up.railway.app:443/api/deals

https://credit-dossier-ip-safe.up.railway.app:443/api/deals (Web Server Misconfiguration: Insecure Content-Type Setting)	Low

Issue Details

Kingdom: Environment
Scan Engine: WEBINSPECT (Dynamic Analysis)
CWE: CWE ID 79, CWE ID 116

Request

GET /api/deals HTTP/1.1
Host: credit-dossier-ip-safe.up.railway.app
Pragma: no-cache
Connection: Keep-Alive
X-WIPP: AscVersion=26.2.0.55
X-RequestManager-Memo:
Category="TrafficMacro.NamedMacro";MacroName="WebProxyGenerated";trid="48ea27e4";stid="109

X-Scan-Memo:
Category="Macro";SID="B5266A6B7CF0C9843DDD4942000B819F";PSID="48F4820E30F621A5E2AE

X-Request-Memo: rid="fe9ca62b";sc="1";thid="128";

© Copyright 2008-2026 Open Text.

Web Server Misconfiguration: Insecure Content-Type Setting	Low

URL: https://credit-dossier-ip-safe.up.railway.app:443/api/deals

https://credit-dossier-ip-safe.up.railway.app:443/api/deals (Web Server Misconfiguration: Insecure Content-Type Setting)	Low

Cookie: credit_dossier_session=d0eAPzIRp8QdGNrD2brN1Zr7r0-kEWvBBheaS1R6PKtDjB05Ngdyitb3WcLSs1uU;CustomCookie=WebInspect209950ZXFA7CF6531B4

Sec-Ch-Ua-Platform: "Windows"
Accept-Language: en-US,en;q=0.9
Sec-Ch-Ua: "Not;A=Brand";v="8", "Chromium";v="150"
Content-Type: application/json
Sec-Ch-Ua-Mobile: ?0
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/150.0.0.0 Safari/537.36
Accept: */*
Sec-Fetch-Site: same-origin
Sec-Fetch-Mode: cors
Sec-Fetch-Dest: empty
Accept-Encoding: gzip, deflate
Priority: u=1, i

Response

...TRUNCATED...none'; object-src 'none'
Content-Type: application/json
Date: Tue, 06 Oct 2026 07:16:38 GMT
p...TRUNCATED...

URL: https://credit-dossier-ip-safe.up.railway.app:443/api/deals/deal_9bf5309

https://credit-dossier-ip-safe.up.railway.app:443/api/deals/deal_9bf5309 (Web Server Misconfiguration: Insecure Content-Type Setting)	Low

Issue Details

Kingdom: Environment
Scan Engine: WEBINSPECT (Dynamic Analysis)
CWE: CWE ID 79, CWE ID 116

Request

GET /api/deals/deal_9bf5309 HTTP/1.1
Host: credit-dossier-ip-safe.up.railway.app
Pragma: no-cache
Connection: Keep-Alive
X-WIPP: AscVersion=26.2.0.55
X-RequestManager-Memo:
Category="TrafficMacro.NamedMacro";MacroName="WebProxyGenerated";trid="48ea27e4";stid="109

X-Scan-Memo:
Category="Macro";SID="36403363A4E9E997518D0CED3580CA15";PSID="B5266A6B7CF0C9843DD

X-Request-Memo: rid="211970bd";sc="1";thid="128";
Cookie: credit_dossier_session=d0eAPzIRp8QdGNrD2brN1Zr7r0-kEWvBBheaS1R6PKtDjB05Ngdyitb3WcLSs1uU;CustomCookie=WebInspect209950ZXFA7CF6531B4

© Copyright 2008-2026 Open Text.

Web Server Misconfiguration: Insecure Content-Type Setting	Low

URL: https://credit-dossier-ip-safe.up.railway.app:443/api/deals/deal_9bf5309

https://credit-dossier-ip-safe.up.railway.app:443/api/deals/deal_9bf5309 (Web Server Misconfiguration: Insecure Content-Type Setting)	Low

Sec-Ch-Ua-Platform: "Windows"
Accept-Language: en-US,en;q=0.9
Sec-Ch-Ua: "Not;A=Brand";v="8", "Chromium";v="150"
Content-Type: application/json
Sec-Ch-Ua-Mobile: ?0
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/150.0.0.0 Safari/537.36
Accept: */*
Sec-Fetch-Site: same-origin
Sec-Fetch-Mode: cors
Sec-Fetch-Dest: empty
Accept-Encoding: gzip, deflate
Priority: u=1, i

Response

...TRUNCATED...none'; object-src 'none'
Content-Type: **application/json**
Date: Tue, 06 Oct 2026 07:16:46 GMT
p...TRUNCATED...

URL: https://credit-dossier-ip-safe.up.railway.app:443/api/deals/deal_9bf5309/report

https://credit-dossier-ip-safe.up.railway.app:443/api/deals/deal_9bf5309/report (Web Server Misconfiguration: Insecure Content-Type Setting)	Low

Issue Details

Kingdom: Environment
Scan Engine: WEBINSPECT (Dynamic Analysis)
CWE: CWE ID 79, CWE ID 116

Request

POST /api/deals/deal_9bf5309/report HTTP/1.1
Host: credit-dossier-ip-safe.up.railway.app
Pragma: no-cache
Connection: Keep-Alive
X-WIPP: AscVersion=26.2.0.55
X-RequestManager-Memo:
Category="TrafficMacro.NamedMacro";MacroName="WebProxyGenerated";trid="48ea27e4";stid="109

X-Scan-Memo:
Category="Macro";SID="37296F89E84A7106F4AFC128D8AA586D";PSID="51B875357F6299A589CC

X-Request-Memo: rid="fded51dd";sc="1";thid="128";
Cookie: credit_dossier_session=DOCIYsfqpz7xbUnjBDXZg1m4803-7iA7L8FrxLsMUtfUb3-FJ4C2ntsn6ovP8Mqg;CustomCookie=WebInspect209950ZXFA7CF6531B49486793E4B5D01CE6C4F

Content-Length: 0

© Copyright 2008-2026 Open Text.

Web Server Misconfiguration: Insecure Content-Type Setting	Low

URL: https://credit-dossier-ip-safe.up.railway.app:443/api/deals/deal_9bf5309/report

https://credit-dossier-ip-safe.up.railway.app:443/api/deals/deal_9bf5309/report (Web Server Misconfiguration: Insecure Content-Type Setting)	Low

Sec-Ch-Ua-Platform: "Windows"
Accept-Language: en-US,en;q=0.9
Sec-Ch-Ua: "Not;A=Brand";v="8", "Chromium";v="150"
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/150.0.0.0 Safari/537.36
Sec-Ch-Ua-Mobile: ?0
Accept: */*
Origin: https://credit-dossier-ip-safe.up.railway.app
Sec-Fetch-Site: same-origin
Sec-Fetch-Mode: cors
Sec-Fetch-Dest: empty
Accept-Encoding: gzip, deflate
Priority: u=1, i

Response

HTTP/1.1 500 Internal Server Error
Content-Type: application/json
Date: Tue, 06 Oct 2026 07:27:14 GMT
Ser...TRUNCATED...

URL: https://credit-dossier-ip-safe.up.railway.app:443/api/deals/deal_9bf5309/sections/deal_9bf5309_client_overview

https://credit-dossier-ip-safe.up.railway.app:443/api/deals/deal_9bf5309/sections/deal_9bf5309_client_overview (Web Server Misconfiguration: Insecure Content-Type Setting)	Low

Issue Details

Kingdom: Environment
Scan Engine: WEBINSPECT (Dynamic Analysis)
CWE: CWE ID 79, CWE ID 116

Request

PATCH /api/deals/deal_9bf5309/sections/deal_9bf5309_client_overview HTTP/1.1
Host: credit-dossier-ip-safe.up.railway.app
Pragma: no-cache
Connection: Keep-Alive
Content-Length: 7494
X-WIPP: AscVersion=26.2.0.55
X-RequestManager-Memo:
Category="TrafficMacro.NamedMacro";MacroName="WebProxyGenerated";trid="48ea27e4";stid="109

X-Scan-Memo:
Category="Macro";SID="E72317245E194660BB4CB3C9F2BFD8F9";PSID="F502955C1241A56F2E94

X-Request-Memo: rid="8a2fd13c";sc="1";thid="128";
Cookie: credit_dossier_session=d0eAPzIRp8QdGNrD2brN1Zr7r0-kEWvBBheaS1R6PKtDjB05Ngdyitb3WcLSs1uU;CustomCookie=WebInspect209950ZXFA7CF6531B4

© Copyright 2008-2026 Open Text.

Web Server Misconfiguration: Insecure Content-Type Setting	Low

URL: https://credit-dossier-ip-safe.up.railway.app:443/api/deals/deal_9bf5309/sections/deal_9bf5309_client_overview

https://credit-dossier-ip-safe.up.railway.app:443/api/deals/deal_9bf5309/sections/deal_9bf5309_client_overview (Web Server Misconfiguration: Insecure Content-Type Setting)	Low

Sec-Ch-Ua-Platform: "Windows"
Accept-Language: en-US,en;q=0.9
Sec-Ch-Ua: "Not;A=Brand";v="8", "Chromium";v="150"
Content-Type: application/json
Sec-Ch-Ua-Mobile: ?0
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/150.0.0.0 Safari/537.36
Accept: */*
Origin: https://credit-dossier-ip-safe.up.railway.app
Sec-Fetch-Site: same-origin
Sec-Fetch-Mode: cors
Sec-Fetch-Dest: empty
Accept-Encoding: gzip, deflate
Priority: u=1, i

{"generated_content":"**1. the Company Background & History**\n- **Legal Entity Details**:\n - **Company Name**: Creditprime (legal entity name as registered).\n - **Incorporation Date**: 2013 [Source : PostgreSQL.credit_dossier.section2_customer_information].\n - **Registered Office**: Pune, India [Source : PostgreSQL.credit_dossier.section2_customer_information].\n - **Business Activities**: Healthcare services operations serving domestic and export customers across Pune, India [Source : PostgreSQL.credit_dossier.section2_customer_information].\n - **KYC Status**: Verified; no directors or beneficial owners identified as Politically Exposed Persons (P...TRUNCATED...

Response

...TRUNCATED...none'; object-src 'none'
Content-Type: application/json
Date: Tue, 06 Oct 2026 07:22:40 GMT
p...TRUNCATED...

URL: https://credit-dossier-ip-safe.up.railway.app:443/api/deals/deal_9bf5309/sections/deal_9bf5309_client_overview/edit-lock

https://credit-dossier-ip-safe.up.railway.app:443/api/deals/deal_9bf5309/sections/deal_9bf5309_client_overview/edit-lock (Web Server Misconfiguration: Insecure Content-Type Setting)	Low

Issue Details

Kingdom: Environment
Scan Engine: WEBINSPECT (Dynamic Analysis)
CWE: CWE ID 79, CWE ID 116

Request

POST /api/deals/deal_9bf5309/sections/deal_9bf5309_client_overview/edit-lock HTTP/1.1
Host: credit-dossier-ip-safe.up.railway.app
Pragma: no-cache
Connection: Keep-Alive

© Copyright 2008-2026 Open Text.

Web Server Misconfiguration: Insecure Content-Type Setting	Low

URL: https://credit-dossier-ip-safe.up.railway.app:443/api/deals/deal_9bf5309/sections/deal_9bf5309_client_overview/edit-lock

https://credit-dossier-ip-safe.up.railway.app:443/api/deals/deal_9bf5309/sections/deal_9bf5309_client_overview/edit-lock (Web Server Misconfiguration: Insecure Content-Type Setting)	Low

X-WIPP: AscVersion=26.2.0.55
X-RequestManager-Memo:
Category="TrafficMacro.NamedMacro";MacroName="WebProxyGenerated";trid="48ea27e4";stid="109'

X-Scan-Memo:
Category="Macro";SID="E14655AB6D742232A35DC7A7CEA223C5";PSID="860A3C95F94A4B2349C

X-Request-Memo: rid="7accafea";sc="1";thid="128";
Cookie: credit_dossier_session=d0eAPzIRp8QdGNrD2brN1Zr7r0-kEWvBBheaS1R6PKtDjB05Ngdyitb3WcLSs1uU;CustomCookie=WebInspect209950ZXFA7CF6531B4

Content-Length: 0
Sec-Ch-Ua-Platform: "Windows"
Accept-Language: en-US,en;q=0.9
Sec-Ch-Ua: "Not;A=Brand";v="8", "Chromium";v="150"
Content-Type: application/json
Sec-Ch-Ua-Mobile: ?0
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/150.0.0.0 Safari/537.36
Accept: */*
Origin: https://credit-dossier-ip-safe.up.railway.app
Sec-Fetch-Site: same-origin
Sec-Fetch-Mode: cors
Sec-Fetch-Dest: empty
Accept-Encoding: gzip, deflate
Priority: u=1, i

Response

...TRUNCATED...none'; object-src 'none'
Content-Type: **application/json**
Date: Tue, 06 Oct 2026 07:21:34 GMT
p...TRUNCATED...

URL: https://credit-dossier-ip-safe.up.railway.app:443/api/deals/deal_9bf5309/sections/deal_9bf5309_client_overview/versions

https://credit-dossier-ip-safe.up.railway.app:443/api/deals/deal_9bf5309/sections/deal_9bf5309_client_overview/versions (Web Server Misconfiguration: Insecure Content-Type Setting)	Low

Issue Details

Kingdom: Environment
Scan Engine: WEBINSPECT (Dynamic Analysis)
CWE: CWE ID 79, CWE ID 116

Request

© Copyright 2008-2026 Open Text.

Web Server Misconfiguration: Insecure Content-Type Setting	Low

URL: https://credit-dossier-ip-safe.up.railway.app:443/api/deals/deal_9bf5309/sections/deal_9bf5309_client_overview/versions

https://credit-dossier-ip-safe.up.railway.app:443/api/deals/deal_9bf5309/sections/deal_9bf5309_client_overview/versions (Web Server Misconfiguration: Insecure Content-Type Setting)	Low

```
GET /api/deals/deal_9bf5309/sections/deal_9bf5309_client_overview/versions HTTP/1.1
Host: credit-dossier-ip-safe.up.railway.app
Pragma: no-cache
Connection: Keep-Alive
X-WIPP: AscVersion=26.2.0.55
X-RequestManager-Memo:
Category="TrafficMacro.NamedMacro";MacroName="WebProxyGenerated";trid="48ea27e4";stid="109

X-Scan-Memo:
Category="Macro";SID="524F422BF9443191C671E3E2DF29527C";PSID="9C5DFD35405D0CBB85A

X-Request-Memo: rid="773e9d39";sc="1";thid="128";
Cookie: credit_dossier_session=d0eAPzIRp8QdGNrD2brN1Zr7r0-
kEWvBBheaS1R6PKtDjB05Ngdyitb3WcLSs1uU;CustomCookie=WebInspect209950ZXFA7CF6531B4

Sec-Ch-Ua-Platform: "Windows"
Accept-Language: en-US,en;q=0.9
Sec-Ch-Ua: "Not;A=Brand";v="8", "Chromium";v="150"
Content-Type: application/json
Sec-Ch-Ua-Mobile: ?0
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko)
Chrome/150.0.0.0 Safari/537.36
Accept: */*
Sec-Fetch-Site: same-origin
Sec-Fetch-Mode: cors
Sec-Fetch-Dest: empty
Accept-Encoding: gzip, deflate
Priority: u=1, i
```

Response

```
...TRUNCATED...none'; object-src 'none'
Content-Type: application/json
Date: Tue, 06 Oct 2026 07:21:40 GMT
p...TRUNCATED...
```

URL: https://credit-dossier-ip-safe.up.railway.app:443/api/deals/deal_9bf5309/sections/deal_9bf5309_executive_summary/edit-lock

https://credit-dossier-ip-safe.up.railway.app:443/api/deals/deal_9bf5309/sections/deal_9bf5309_executive_summary/edit-lock (Web Server Misconfiguration: Insecure Content-Type Setting)	Low

Issue Details

Kingdom: Environment
Scan Engine: WEBINSPECT (Dynamic Analysis)
CWE: CWE ID 79, CWE ID 116

© Copyright 2008-2026 Open Text.

Web Server Misconfiguration: Insecure Content-Type Setting	Low

URL: https://credit-dossier-ip-safe.up.railway.app:443/api/deals/deal_9bf5309/sections/deal_9bf5309_executive_summary/edit-lock

https://credit-dossier-ip-safe.up.railway.app:443/api/deals/deal_9bf5309/sections/deal_9bf5309_executive_summary/edit-lock (Web Server Misconfiguration: Insecure Content-Type Setting)	Low

Request

```
POST /api/deals/deal_9bf5309/sections/deal_9bf5309_executive_summary/edit-lock HTTP/1.1
Host: credit-dossier-ip-safe.up.railway.app
Pragma: no-cache
Connection: Keep-Alive
X-WIPP: AscVersion=26.2.0.55
X-RequestManager-Memo:
Category="TrafficMacro.NamedMacro";MacroName="WebProxyGenerated";trid="48ea27e4";stid="109

X-Scan-Memo:
Category="Macro";SID="A00DD4D91D528DB730A23D62F689FFCB";PSID="E955847260B43BEE824

X-Request-Memo: rid="80bb1eba";sc="1";thid="128";
Cookie: credit_dossier_session=DOCIYsfqpz7xbUnjBDXZg1m4803-7iA7L8FrxLsMUtfUb3-
FJ4C2ntsn6ovP8Mqg;CustomCookie=WebInspect209950ZXFA7CF6531B49486793E4B5D01CE6C4F

Content-Length: 0
Sec-Ch-Ua-Platform: "Windows"
Accept-Language: en-US,en;q=0.9
Sec-Ch-Ua: "Not;A=Brand";v="8", "Chromium";v="150"
Content-Type: application/json
Sec-Ch-Ua-Mobile: ?0
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko)
Chrome/150.0.0.0 Safari/537.36
Accept: */*
Origin: https://credit-dossier-ip-safe.up.railway.app
Sec-Fetch-Site: same-origin
Sec-Fetch-Mode: cors
Sec-Fetch-Dest: empty
Accept-Encoding: gzip, deflate
Priority: u=1, i
```

Response

```
...TRUNCATED...none'; object-src 'none'
Content-Type: application/json
Date: Tue, 06 Oct 2026 07:26:18 GMT
p...TRUNCATED...
```

URL: https://credit-dossier-ip-safe.up.railway.app:443/api/deals/deal_9bf5309/sections/deal_9bf5309_executive_summary/template

https://credit-dossier-ip-safe.up.railway.app:443/api/deals/deal_9bf5309/sections/deal_9bf5309_executive_summary/template (Web Server Misconfiguration: Insecure Content-Type Setting)	Low

Issue Details

© Copyright 2008-2026 Open Text.

Web Server Misconfiguration: Insecure Content-Type Setting	Low
URL: https://credit-dossier-ip-safe.up.railway.app:443/api/deals/deal_9bf5309/sections/deal_9bf5309_executive_summary/template	
https://credit-dossier-ip-safe.up.railway.app:443/api/deals/deal_9bf5309/sections/deal_9bf5309_executive_summary/template (Web Server Misconfiguration: Insecure Content-Type Setting)	Low

Kingdom: Environment
Scan Engine: WEBINSPECT (Dynamic Analysis)
CWE: CWE ID 79, CWE ID 116

Request

```
DELETE /api/deals/deal_9bf5309/sections/deal_9bf5309_executive_summary/template HTTP/1.1
Host: credit-dossier-ip-safe.up.railway.app
Pragma: no-cache
Connection: Keep-Alive
X-WIPP: AscVersion=26.2.0.55
X-RequestManager-Memo:
Category="TrafficMacro.NamedMacro";MacroName="WebProxyGenerated";trid="48ea27e4";stid="109

X-Scan-Memo:
Category="Macro";SID="BB9F1213C01E6FE6D1CCEBB4182F92FD";PSID="A00DD4D91D528DB730

X-Request-Memo: rid="5e15e888";sc="1";thid="128";
Cookie: credit_dossier_session=DOCIYsfqpz7xbUnjBDXZg1m4803-7iA7L8FrxLsMUtfUb3-
FJ4C2ntsn6ovP8Mqg;CustomCookie=WebInspect209950ZXFA7CF6531B49486793E4B5D01CE6C4F

Sec-Ch-Ua-Platform: "Windows"
Accept-Language: en-US,en;q=0.9
Sec-Ch-Ua: "Not;A=Brand";v="8", "Chromium";v="150"
Content-Type: application/json
Sec-Ch-Ua-Mobile: ?0
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko)
Chrome/150.0.0.0 Safari/537.36
Accept: */*
Origin: https://credit-dossier-ip-safe.up.railway.app
Sec-Fetch-Site: same-origin
Sec-Fetch-Mode: cors
Sec-Fetch-Dest: empty
Accept-Encoding: gzip, deflate
Priority: u=1, i
```

Response

```
...TRUNCATED...none'; object-src 'none'
Content-Type: application/json
Date: Tue, 06 Oct 2026 07:26:21 GMT
p...TRUNCATED...
```


© Copyright 2008-2026 Open Text.

Web Server Misconfiguration: Insecure Content-Type Setting	Low
URL: https://credit-dossier-ip-safe.up.railway.app:443/api/deals/deal_9bf5309/sections/deal_9bf5309_relationship_summary	
https://credit-dossier-ip-safe.up.railway.app:443/api/deals/deal_9bf5309/sections/deal_9bf5309_relationship_summary (Web Server Misconfiguration: Insecure Content-Type Setting)	Low

Issue Details

Kingdom: Environment
Scan Engine: WEBINSPECT (Dynamic Analysis)
CWE: CWE ID 79, CWE ID 116

Request

```
PATCH /api/deals/deal_9bf5309/sections/deal_9bf5309_relationship_summary HTTP/1.1
Host: credit-dossier-ip-safe.up.railway.app
Pragma: no-cache
Connection: Keep-Alive
Content-Length: 70
X-WIPP: AscVersion=26.2.0.55
X-RequestManager-Memo:
Category="TrafficMacro.NamedMacro";MacroName="WebProxyGenerated";trid="48ea27e4";stid="109

X-Scan-Memo:
Category="Macro";SID="0D36A6154056D6F1BF78F8DFE9E7C3F5";PSID="D75C4CA71DCA53B05C

X-Request-Memo: rid="7a9eb1ec";sc="1";thid="128";
Cookie: credit_dossier_session=d0eAPzIRp8QdGNrD2brN1Zr7r0-
kEWvBBheaS1R6PKtDjB05Ngdyitb3WcLSs1uU;CustomCookie=WebInspect209950ZXFA7CF6531B4

Sec-Ch-Ua-Platform: "Windows"
Accept-Language: en-US,en;q=0.9
Sec-Ch-Ua: "Not;A=Brand";v="8", "Chromium";v="150"
Content-Type: application/json
Sec-Ch-Ua-Mobile: ?0
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko)
Chrome/150.0.0.0 Safari/537.36
Accept: */*
Origin: https://credit-dossier-ip-safe.up.railway.app
Sec-Fetch-Site: same-origin
Sec-Fetch-Mode: cors
Sec-Fetch-Dest: empty
Accept-Encoding: gzip, deflate
Priority: u=1, i

{"custom_instructions":"forge some of the financial if not available"}
```

Response

```
...TRUNCATED...none'; object-src 'none'
Content-Type: application/json
Date: Tue, 06 Oct 2026 07:17:24 GMT
p...TRUNCATED...
```


© Copyright 2008-2026 Open Text.

Web Server Misconfiguration: Insecure Content-Type Setting	Low
URL: https://credit-dossier-ip-safe.up.railway.app:443/api/deals/deal_9bf5309/versions	
https://credit-dossier-ip-safe.up.railway.app:443/api/deals/deal_9bf5309/versions (Web Server Misconfiguration: Insecure Content-Type Setting)	Low

Issue Details

Kingdom: Environment
Scan Engine: WEBINSPECT (Dynamic Analysis)
CWE: CWE ID 79, CWE ID 116

Request

POST /api/deals/deal_9bf5309/versions HTTP/1.1
Host: credit-dossier-ip-safe.up.railway.app
Pragma: no-cache
Connection: Keep-Alive
X-WIPP: AscVersion=26.2.0.55
X-RequestManager-Memo:
Category="TrafficMacro.NamedMacro";MacroName="WebProxyGenerated";trid="48ea27e4";stid="109'

X-Scan-Memo:
Category="Macro";SID="E377506CE3414200C48BDC08001A20AD";PSID="9E896A2727D635ECFA0

X-Request-Memo: rid="6ac6142e";sc="1";thid="128";
Cookie: credit_dossier_session=DOCIYsfqpz7xbUnjBDXZg1m4803-7iA7L8FrxLsMUtfUb3-FJ4C2ntsn6ovP8Mqg;CustomCookie=WebInspect209950ZXFA7CF6531B49486793E4B5D01CE6C4F

Content-Length: 12
Sec-Ch-Ua-Platform: "Windows"
Accept-Language: en-US,en;q=0.9
Sec-Ch-Ua: "Not;A=Brand";v="8", "Chromium";v="150"
Content-Type: application/json
Sec-Ch-Ua-Mobile: ?0
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/150.0.0.0 Safari/537.36
Accept: */*
Origin: https://credit-dossier-ip-safe.up.railway.app
Sec-Fetch-Site: same-origin
Sec-Fetch-Mode: cors
Sec-Fetch-Dest: empty
Accept-Encoding: gzip, deflate
Priority: u=1, i

{"notes":""}

Response

...TRUNCATED...none'; object-src 'none'
Content-Type: **application/json**
Date: Tue, 06 Oct 2026 07:26:48 GMT
p...TRUNCATED...

© Copyright 2008-2026 Open Text.

Web Server Misconfiguration: Insecure Content-Type Setting	Low
URL: https://credit-dossier-ip-safe.up.railway.app:443/api/deals/search	
https://credit-dossier-ip-safe.up.railway.app:443/api/deals/search (Web Server Misconfiguration: Insecure Content-Type Setting)	Low

Issue Details

Kingdom: Environment
Scan Engine: WEBINSPECT (Dynamic Analysis)
CWE: CWE ID 79, CWE ID 116

Request

POST /api/deals/search HTTP/1.1
Host: credit-dossier-ip-safe.up.railway.app
Pragma: no-cache
Connection: Keep-Alive
Content-Length: 38
Sec-Ch-Ua-Platform: "Windows"
Accept-Language: en-US,en;q=0.9
Sec-Ch-Ua: "Not;A=Brand";v="8", "Chromium";v="150"
Content-Type: application/json
Sec-Ch-Ua-Mobile: ?0
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/150.0.0.0 Safari/537.36
Accept: */*
Origin: https://credit-dossier-ip-safe.up.railway.app
Sec-Fetch-Site: same-origin
Sec-Fetch-Mode: cors
Sec-Fetch-Dest: empty
Accept-Encoding: gzip, deflate
Priority: u=1, i
X-WIPP: AscVersion=26.2.0.55
X-RequestManager-Memo:
Category="TrafficMacro.NamedMacro";MacroName="WebProxyGenerated";trid="48ea27e4";stid="109'

X-Scan-Memo:
Category="Macro";SID="46575E2A3CCC2ECAC9FE47D2EF3644C6";PSID="9CE997ED8200A67693I

X-Request-Memo: rid="42dcdd5f";sc="1";thid="128";
Cookie:
CustomCookie=WebInspect209950ZXFA7CF6531B49486793E4B5D01CE6C4F4Y9EB5;credit_dossie
kEWvBBheaS1R6PKtDjB05Ngdyitb3WcLSs1uU

{"status":"In Progress","search":null}

Response

...TRUNCATED...none'; object-src 'none'
Content-Type: **application/json**
Date: Tue, 06 Oct 2026 07:23:31 GMT
p...TRUNCATED...

© Copyright 2008-2026 Open Text.

Web Server Misconfiguration: Server Error Message — Low

URL: https://credit-dossier-ip-safe.up.railway.app:443/api/deals/deal_9bf5309/export/docx

https://credit-dossier-ip-safe.up.railway.app:443/api/deals/deal_9bf5309/export/docx (Web Server Misconfiguration: Server Error Message) — **Low**

Issue Details

Kingdom: Environment
Scan Engine: WEBINSPECT (Dynamic Analysis)
CWE: CWE ID 550

Request

```
POST /api/deals/deal_9bf5309/export/docx HTTP/1.1
Host: credit-dossier-ip-safe.up.railway.app
Pragma: no-cache
Connection: Keep-Alive
X-WIPP: AscVersion=26.2.0.55
X-RequestManager-Memo:
Category="TrafficMacro.NamedMacro";MacroName="WebProxyGenerated";trid="48ea27e4";stid="109

X-Scan-Memo:
Category="Macro";SID="151365B6734B7B54E3AF7ED035D29312";PSID="2677C0360EF20BF62359

X-Request-Memo: rid="3f0fdeb6";sc="1";thid="128";
Cookie: credit_dossier_session=DOCIYsfqpz7xbUnjBDXZg1m4803-7iA7L8FrxLsMUtfUb3-
FJ4C2ntsn6ovP8Mqg;CustomCookie=WebInspect209950ZXFA7CF6531B49486793E4B5D01CE6C4F

Content-Length: 0
Sec-Ch-Ua-Platform: "Windows"
Accept-Language: en-US,en;q=0.9
Sec-Ch-Ua: "Not;A=Brand";v="8", "Chromium";v="150"
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko)
Chrome/150.0.0.0 Safari/537.36
Sec-Ch-Ua-Mobile: ?0
Accept: */*
Origin: https://credit-dossier-ip-safe.up.railway.app
Sec-Fetch-Site: same-origin
Sec-Fetch-Mode: cors
Sec-Fetch-Dest: empty
Accept-Encoding: gzip, deflate
Priority: u=1, i
```

Response

```
HTTP/1.1 500 Internal Server Error
Content-Type: ap...TRUNCATED...
```

URL: https://credit-dossier-ip-safe.up.railway.app:443/api/deals/deal_9bf5309/export/pdf

https://credit-dossier-ip-safe.up.railway.app:443/api/deals/deal_9bf5309/export/pdf (Web Server Misconfiguration: Server Error Message) — **Low**

Issue Details

Kingdom: Environment
Scan Engine: WEBINSPECT (Dynamic Analysis)
CWE: CWE ID 550

© Copyright 2008-2026 Open Text.

Web Server Misconfiguration: Server Error Message	Low

URL: https://credit-dossier-ip-safe.up.railway.app:443/api/deals/deal_9bf5309/export/pdf

https://credit-dossier-ip-safe.up.railway.app:443/api/deals/deal_9bf5309/export/pdf (Web Server Misconfiguration: Server Error Message)	Low

Request

POST /api/deals/deal_9bf5309/export/pdf HTTP/1.1
Host: credit-dossier-ip-safe.up.railway.app
Pragma: no-cache
Connection: Keep-Alive
X-WIPP: AscVersion=26.2.0.55
X-RequestManager-Memo:
Category="TrafficMacro.NamedMacro";MacroName="WebProxyGenerated";trid="48ea27e4";stid="109

X-Scan-Memo:
Category="Macro";SID="2677C0360EF20BF62359F811A22B3099";PSID="1498F04B6FB2DC496F29

X-Request-Memo: rid="fab376ab";sc="1";thid="128";
Cookie: credit_dossier_session=DOCIYsfqpz7xbUnjBDXZg1m4803-7iA7L8FrxLsMUtfUb3-FJ4C2ntsn6ovP8Mqg;CustomCookie=WebInspect209950ZXFA7CF6531B49486793E4B5D01CE6C4F

Content-Length: 0
Sec-Ch-Ua-Platform: "Windows"
Accept-Language: en-US,en;q=0.9
Sec-Ch-Ua: "Not;A=Brand";v="8", "Chromium";v="150"
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/150.0.0.0 Safari/537.36
Sec-Ch-Ua-Mobile: ?0
Accept: */*
Origin: https://credit-dossier-ip-safe.up.railway.app
Sec-Fetch-Site: same-origin
Sec-Fetch-Mode: cors
Sec-Fetch-Dest: empty
Accept-Encoding: gzip, deflate
Priority: u=1, i

Response

HTTP/1.1 500 Internal Server Error
Content-Type: ap...TRUNCATED...

URL: https://credit-dossier-ip-safe.up.railway.app:443/api/deals/deal_9bf5309/export/pptx

https://credit-dossier-ip-safe.up.railway.app:443/api/deals/deal_9bf5309/export/pptx (Web Server Misconfiguration: Server Error Message)	Low

Issue Details

Kingdom: Environment
Scan Engine: WEBINSPECT (Dynamic Analysis)
CWE: CWE ID 550

Request

POST /api/deals/deal_9bf5309/export/pptx HTTP/1.1
Host: credit-dossier-ip-safe.up.railway.app

© Copyright 2008-2026 Open Text.

Web Server Misconfiguration: Server Error Message	Low

URL: https://credit-dossier-ip-safe.up.railway.app:443/api/deals/deal_9bf5309/export/pptx

https://credit-dossier-ip-safe.up.railway.app:443/api/deals/deal_9bf5309/export/pptx (Web Server Misconfiguration: Server Error Message)	Low

Pragma: no-cache
Connection: Keep-Alive
X-WIPP: AscVersion=26.2.0.55
X-RequestManager-Memo:
Category="TrafficMacro.NamedMacro";MacroName="WebProxyGenerated";trid="48ea27e4";stid="109

X-Scan-Memo:
Category="Macro";SID="1498F04B6FB2DC496F296F323A3E6215";PSID="37296F89E84A7106F4AF

X-Request-Memo: rid="c11dcd33";sc="1";thid="128";
Cookie: credit_dossier_session=DOCIYsfqpz7xbUnjBDXZg1m4803-7iA7L8FrxLsMUtfUb3-FJ4C2ntsn6ovP8Mqg;CustomCookie=WebInspect209950ZXFA7CF6531B49486793E4B5D01CE6C4F

Content-Length: 0
Sec-Ch-Ua-Platform: "Windows"
Accept-Language: en-US,en;q=0.9
Sec-Ch-Ua: "Not;A=Brand";v="8", "Chromium";v="150"
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/150.0.0.0 Safari/537.36
Sec-Ch-Ua-Mobile: ?0
Accept: */*
Origin: https://credit-dossier-ip-safe.up.railway.app
Sec-Fetch-Site: same-origin
Sec-Fetch-Mode: cors
Sec-Fetch-Dest: empty
Accept-Encoding: gzip, deflate
Priority: u=1, i

Response

HTTP/1.1 500 Internal Server Error
Content-Type: ap...TRUNCATED...

URL: https://credit-dossier-ip-safe.up.railway.app:443/api/deals/deal_9bf5309/report

https://credit-dossier-ip-safe.up.railway.app:443/api/deals/deal_9bf5309/report (Web Server Misconfiguration: Server Error Message)	Low

Issue Details

Kingdom: Environment
Scan Engine: WEBINSPECT (Dynamic Analysis)
CWE: CWE ID 550

Request

POST /api/deals/deal_9bf5309/report HTTP/1.1
Host: credit-dossier-ip-safe.up.railway.app
Pragma: no-cache
Connection: Keep-Alive
X-WIPP: AscVersion=26.2.0.55
X-RequestManager-Memo:

© Copyright 2008-2026 Open Text.

Web Server Misconfiguration: Server Error Message	Low

URL: https://credit-dossier-ip-safe.up.railway.app:443/api/deals/deal_9bf5309/report

https://credit-dossier-ip-safe.up.railway.app:443/api/deals/deal_9bf5309/report (Web Server Misconfiguration: Server Error Message)	Low

Category="TrafficMacro.NamedMacro";MacroName="WebProxyGenerated";trid="48ea27e4";stid="109'

X-Scan-Memo:
Category="Macro";SID="37296F89E84A7106F4AFC128D8AA586D";PSID="51B875357F6299A589CC

X-Request-Memo: rid="fded51dd";sc="1";thid="128";
Cookie: credit_dossier_session=DOCIYsfqpz7xbUnjBDXZg1m4803-7iA7L8FrxLsMUtfUb3-FJ4C2ntsn6ovP8Mqg;CustomCookie=WebInspect209950ZXFA7CF6531B49486793E4B5D01CE6C4F

Content-Length: 0
Sec-Ch-Ua-Platform: "Windows"
Accept-Language: en-US,en;q=0.9
Sec-Ch-Ua: "Not;A=Brand";v="8", "Chromium";v="150"
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/150.0.0.0 Safari/537.36
Sec-Ch-Ua-Mobile: ?0
Accept: */*
Origin: https://credit-dossier-ip-safe.up.railway.app
Sec-Fetch-Site: same-origin
Sec-Fetch-Mode: cors
Sec-Fetch-Dest: empty
Accept-Encoding: gzip, deflate
Priority: u=1, i

Response

HTTP/1.1 **500** Internal Server Error
Content-Type: ap...TRUNCATED...

Web Server Misconfiguration: Unprotected Directory	Low

URL: https://credit-dossier-ip-safe.up.railway.app:443/admin/

https://credit-dossier-ip-safe.up.railway.app:443/admin/ (Web Server Misconfiguration: Unprotected Directory)	Low

Issue Details

Kingdom: Environment
Scan Engine: WEBINSPECT (Dynamic Analysis)
CWE: CWE ID 527, CWE ID 538, CWE ID 548, CWE ID 552

Request

GET **/admin/** HTTP/1.1
Referer: https://credit-dossier-ip-safe.up.railway.app/assets/triangle-alert-BfPUAUia.js
Accept: */*
Pragma: no-cache
Accept-Encoding: gzip, deflate
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:130.0) Gecko/20100101 Firefox/130.0
Host: credit-dossier-ip-safe.up.railway.app
Connection: Keep-Alive
X-WIPP: AscVersion=26.2.0.55

© Copyright 2008-2026 Open Text.

Web Server Misconfiguration: Unprotected Directory	Low

URL: https://credit-dossier-ip-safe.up.railway.app:443/admin/

https://credit-dossier-ip-safe.up.railway.app:443/admin/ (Web Server Misconfiguration: Unprotected Directory)	Low

X-Scan-Memo:
Category="Audit.Attack";SID="FFCC5F06F4586A6B9DDB4122EA3FE118";PSID="4E3FFB363DFFA6

X-RequestManager-Memo: stid="117";stmi="0";sc="1";rid="2a18e40f";
X-Request-Memo: rid="0e207f12";sc="1";thid="72";
Cookie: CustomCookie=WebInspect209950ZXFA7CF6531B49486793E4B5D01CE6C4F4Y9EB5

Response

HTTP/1.1 307 Temporary Redirect
content-security-po...TRUNCATED...

https://credit-dossier-ip-safe.up.railway.app:443/admin/ (Web Server Misconfiguration: Unprotected Directory)	Low

Issue Details

Kingdom: Environment
Scan Engine: WEBINSPECT (Dynamic Analysis)
CWE: CWE ID 527, CWE ID 538, CWE ID 548, CWE ID 552

Request

GET /admin/ HTTP/1.1
Referer: https://credit-dossier-ip-safe.up.railway.app/
Accept: */*
Pragma: no-cache
Accept-Encoding: gzip, deflate
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:130.0) Gecko/20100101 Firefox/130.0
Host: credit-dossier-ip-safe.up.railway.app
Connection: Keep-Alive
X-WIPP: AscVersion=26.2.0.55
X-Scan-Memo:
Category="Audit.Attack";SID="D2EA80210BA2035318462AB5B3194E66";PSID="3762DE85075728E7
f305852be435";AttackSequence="0";AttackParamDesc="";AttackParamIndex="0";AttackParamSubInde

X-RequestManager-Memo: stid="117";stmi="0";sc="1";rid="bf2ef8fc";
X-Request-Memo: rid="e793d523";sc="1";thid="72";
Cookie: CustomCookie=WebInspect209950ZXFA7CF6531B49486793E4B5D01CE6C4F4Y9EB5

Response

HTTP/1.1 307 Temporary Redirect
content-security-po...TRUNCATED...

URL: https://credit-dossier-ip-safe.up.railway.app:443/dashboard/

https://credit-dossier-ip-safe.up.railway.app:443/dashboard/ (Web Server Misconfiguration: Unprotected Directory)	Low

Issue Details

Kingdom: Environment
Scan Engine: WEBINSPECT (Dynamic Analysis)

© Copyright 2008-2026 Open Text.

Web Server Misconfiguration: Unprotected Directory	Low

URL: https://credit-dossier-ip-safe.up.railway.app:443/dashboard/

https://credit-dossier-ip-safe.up.railway.app:443/dashboard/ (Web Server Misconfiguration: Unprotected Directory)	Low

CWE: CWE ID 527, CWE ID 538, CWE ID 548, CWE ID 552

Request

GET /dashboard/ HTTP/1.1
Referer: https://credit-dossier-ip-safe.up.railway.app/assets/triangle-alert-BfPUAUia.js
Accept: */*
Pragma: no-cache
Accept-Encoding: gzip, deflate
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:130.0) Gecko/20100101 Firefox/130.0
Host: credit-dossier-ip-safe.up.railway.app
Connection: Keep-Alive
X-WIPP: AscVersion=26.2.0.55
X-Scan-Memo:
Category="Audit.Attack";SID="2B61996733F8F551C8C251B88E29E9E7";PSID="4E3FFB363DFFA60I

X-RequestManager-Memo: stid="117";stmi="0";sc="1";rid="18bb1e07";
X-Request-Memo: rid="6935760b";sc="1";thid="72";
Cookie: CustomCookie=WebInspect209950ZXFA7CF6531B49486793E4B5D01CE6C4F4Y9EB5

Response

HTTP/1.1 307 Temporary Redirect
content-security-po...TRUNCATED...

URL: https://credit-dossier-ip-safe.up.railway.app:443/login/

https://credit-dossier-ip-safe.up.railway.app:443/login/ (Web Server Misconfiguration: Unprotected Directory)	Low

Issue Details

Kingdom: Environment
Scan Engine: WEBINSPECT (Dynamic Analysis)
CWE: CWE ID 527, CWE ID 538, CWE ID 548, CWE ID 552

Request

GET /login/ HTTP/1.1
Referer: https://credit-dossier-ip-safe.up.railway.app/assets/triangle-alert-BfPUAUia.js
Accept: */*
Pragma: no-cache
Accept-Encoding: gzip, deflate
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:130.0) Gecko/20100101 Firefox/130.0
Host: credit-dossier-ip-safe.up.railway.app
Connection: Keep-Alive
X-WIPP: AscVersion=26.2.0.55
X-Scan-Memo:
Category="Audit.Attack";SID="53594D4F4DE5EA5B31547E220A4607F6";PSID="4E3FFB363DFFA60

X-RequestManager-Memo: stid="117";stmi="0";sc="1";rid="4f36e1dd";
X-Request-Memo: rid="41f95b7c";sc="1";thid="72";

© Copyright 2008-2026 Open Text.

Web Server Misconfiguration: Unprotected Directory	Low
URL: https://credit-dossier-ip-safe.up.railway.app:443/login/	
https://credit-dossier-ip-safe.up.railway.app:443/login/ (Web Server Misconfiguration: Unprotected Directory)	**Low**

Cookie: CustomCookie=WebInspect209950ZXFA7CF6531B49486793E4B5D01CE6C4F4Y9EB5

Response

HTTP/1.1 307 Temporary Redirect
content-security-po...TRUNCATED...

Web Server Misconfiguration: Weak Authentication	Low
URL: https://credit-dossier-ip-safe.up.railway.app:443/api/auth/me	
https://credit-dossier-ip-safe.up.railway.app:443/api/auth/me (Web Server Misconfiguration: Weak Authentication)	**Low**

Issue Details

Kingdom: Environment
Scan Engine: WEBINSPECT (Dynamic Analysis)
CWE: CWE ID 287

Request

GET /api/auth/me HTTP/1.1
Host: credit-dossier-ip-safe.up.railway.app
Pragma: no-cache
Connection: Keep-Alive
Sec-Ch-Ua-Platform: "Windows"
Accept-Language: en-US,en;q=0.9
Sec-Ch-Ua: "Not;A=Brand";v="8", "Chromium";v="150"
Content-Type: application/json
Sec-Ch-Ua-Mobile: ?0
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/150.0.0.0 Safari/537.36
Accept: */*
Sec-Fetch-Site: same-origin
Sec-Fetch-Mode: cors
Sec-Fetch-Dest: empty
Accept-Encoding: gzip, deflate
Priority: u=1, i
X-WIPP: AscVersion=26.2.0.55
X-RequestManager-Memo:
Category="TrafficMacro.NamedMacro";MacroName="WebProxyGenerated";trid="48ea27e4";stid="109

X-Scan-Memo:
Category="Macro";SID="F9DD5B8DCC1C3CB86B47E7FB4D97F678";PSID="04F1631807B0A49A41

X-Request-Memo: rid="08244435";sc="1";thid="128";
Cookie: CustomCookie=WebInspect209950ZXFA7CF6531B49486793E4B5D01CE6C4F4Y9EB5

Response

HTTP/1.1 401 Unauthorized
content-security-policy: ...TRUNCATED...

© Copyright 2008-2026 Open Text.

Web Server Misconfiguration: Weak Authentication	Low

URL: https://credit-dossier-ip-safe.up.railway.app:443/api/auth/me

https://credit-dossier-ip-safe.up.railway.app:443/api/auth/me (Web Server Misconfiguration: Weak Authentication)	Low

...TRUNCATED...way-edge: sin1
Connection: keep-alive

{"error_code":"AUTH-003","detail":"Ple...TRUNCATED...

URL: https://credit-dossier-ip-safe.up.railway.app:443/api/deals/deal_9bf5309/sections/deal_9bf5309_relationship_summary

https://credit-dossier-ip-safe.up.railway.app:443/api/deals/deal_9bf5309/sections/deal_9bf5309_relationship_summary (Web Server Misconfiguration: Weak Authentication)	Low

Issue Details

Kingdom: Environment
Scan Engine: WEBINSPECT (Dynamic Analysis)
CWE: CWE ID 287

Request

PATCH /api/deals/deal_9bf5309/sections/deal_9bf5309_relationship_summary HTTP/1.1
Host: credit-dossier-ip-safe.up.railway.app
Pragma: no-cache
Referer: https://credit-dossier-ip-safe.up.railway.app/api/deals/deal_9bf5309/sections/deal_9bf5309_relationship_summary
Connection: Keep-Alive
Content-Length: 241
X-WIPP: AscVersion=26.2.0.55
X-Scan-Memo: Category="Audit.Attack";SID="1F75D8C4325CBDECA366B8F9CF898DC6";PSID="93AF898E8EC710a69f-9f4323960f26";AttackSequence="0";AttackParamDesc="%24.custom_instructions";AttackParamIr

X-RequestManager-Memo: stid="119";stmi="0";sc="1";rid="c233dfca";
X-Request-Memo: rid="ee25a224";sc="1";thid="73";
Cookie: CustomCookie=WebInspect209950ZXFA7CF6531B49486793E4B5D01CE6C4F4Y9EB5
Sec-Ch-Ua-Platform: "Windows"
Accept-Language: en-US,en;q=0.9
Sec-Ch-Ua: "Not;A=Brand";v="8", "Chromium";v="150"
Content-Type: application/json
Sec-Ch-Ua-Mobile: ?0
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/150.0.0.0 Safari/537.36
Accept: */*
Origin: https://credit-dossier-ip-safe.up.railway.app
Sec-Fetch-Site: same-origin
Sec-Fetch-Mode: cors
Sec-Fetch-Dest: empty
Accept-Encoding: gzip, deflate
Priority: u=1, i

{"custom_instructions":"%

© Copyright 2008-2026 Open Text.

Web Server Misconfiguration: Weak Authentication	Low
URL: https://credit-dossier-ip-safe.up.railway.app:443/api/deals/deal_9bf5309/sections/deal_9bf5309_relationship_summary	
https://credit-dossier-ip-safe.up.railway.app:443/api/deals/deal_9bf5309/sections/deal_9bf5309_relationship_summary (Web Server Misconfiguration: Weak Authentication)	Low

{(#attr['com.opensymphony.xwork2.util.ValueStack.ValueStack'].context['com.opensymphony.xwork2.d

Response

HTTP/1.1 401 Unauthorized
access-control-allow-cred...TRUNCATED...

...TRUNCATED...way-edge: sin1
Connection: keep-alive

{"error_code":"AUTH-003","detail":"Ple...TRUNCATED...

Path Manipulation: Special Characters	Medium
URL: https://credit-dossier-ip-safe.up.railway.app:443/assets/triangle-alert-BfPUAUia.jsHTTP/1.1/../../triangle-alert-BfPUAUia.js	
https://credit-dossier-ip-safe.up.railway.app:443/assets/triangle-alert-BfPUAUia.jsHTTP/1.1/../../triangle-alert-BfPUAUia.js (Path Manipulation: Special Characters)	Medium

Issue Details

Kingdom: Input Validation and Representation
Scan Engine: WEBINSPECT (Dynamic Analysis)
CWE: CWE ID 156, CWE ID 158

Request

GET /assets/triangle-alert-BfPUAUia.js HTTP/1.1/../../triangle-alert-BfPUAUia.js HTTP/1.1
Referer: https://credit-dossier-ip-safe.up.railway.app:443/
Host: credit-dossier-ip-safe.up.railway.app
Accept: */*
Accept-Language: en-US,en;q=0.5
Accept-Encoding: gzip, deflate
Sec-Fetch-Dest: script
Sec-Fetch-Mode: cors
Sec-Fetch-Site: same-origin
Priority: u=1
Pragma: no-cache
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:130.0) Gecko/20100101 Firefox/130.0
Connection: Keep-Alive
X-WIPP: AscVersion=26.2.0.55
X-Scan-Memo:
Category="Audit.Attack";SID="1E180CCF04EA5B23966314736BA80096";PSID="4E3FFB363DFFA60
b78f-07d113702573";AttackSequence="0";AttackParamDesc="ControChars";AttackParamIndex="0";At

X-RequestManager-Memo: stid="113";stmi="0";sc="1";rid="e0d7b1e1";
X-Request-Memo: rid="8da19ba8";sc="1";thid="114";
Cookie: CustomCookie=WebInspect209950ZXFA7CF6531B49486793E4B5D01CE6C4F4Y9EB5

Response

© Copyright 2008-2026 Open Text.

Path Manipulation: Special Characters	Medium
URL: https://credit-dossier-ip-safe.up.railway.app:443/assets/triangle-alert-BfPUAUia.jsHTTP/1.1/../../triangle-alert-BfPUAUia.js	
https://credit-dossier-ip-safe.up.railway.app:443/assets/triangle-alert-BfPUAUia.jsHTTP/1.1/../../triangle-alert-BfPUAUia.js (Path Manipulation: Special Characters)	Medium

HTTP/1.1 200 OK
Cache-Control: public, max-age=31536000, immutable
Content-Type: application/javascript; charset=utf-8...TRUNCATED...

© Copyright 2008-2026 Open Text.

Category Descriptions

Below is information about all Categories of issue vulnerabilities found in this project.

Cache Management: Insecure Policy

Explanation

Summary: WebInspect has detected a potentially unsafe cache control policy for secure content. While content transmitted over an SSL/TLS channel is expected to guarantee confidentiality, administrators must ensure that caching of sensitive content is disabled unless absolutely needed. The misconception that secure content caching is disabled by default by user-agents could cause the application to fail the organization's cache policy. An unsafe specification such as Cache-Control: public instructs the browser to persistently cache the content on the hard drive. Cache-Control with no-store in the value must be set to prevent browsers from persisting content. Browsers and intermediate proxies will still persists with the no-cache directive. However, they will revalidate the content with the server before serving content from cache. The private directive prevents intermediate proxies from caching content. Missing Cache-Control policy header results in browsers caching content regardless of whether it is served over HTTP or HTTPS.

- `Cache-Control: no-store`

Implication: Insecure caching policies could lead to content spoofing or information theft. SSL provides secure encrypted channel to transfer information from source to user. The information served over SSL is considered sensitive and trusted to be only available to the requestor. However, caching this content on disk in temporary internet files or on an intermediate proxy server can compromise that trust by exposing it to anyone who has access to the temporary storage or proxy cache. Content served over SSL should have cache disabled.
Execution: Send a request to / and inspect the `Cache-Control` header value.
Reference Info:
Server Configuration: IIS http://support.microsoft.com/kb/247404 Apache https://httpd.apache.org/docs/2.4/caching.html RFC 9111 Section 5.2 Cache Control https://datatracker.ietf.org/doc/html/rfc9111#section-5.2 Browser Cache FAQ https://www.owasp.org/index.php/OWASP_Application_Security_FAQ#Browser_Cache Caching Tutorial https://www.mnot.net/cache_docs/

Recommendation

Set the `Cache-Control` directive to `no-store`.
no-cache For sensitive resources requiring user authentication, servers can send the no-cache directive to prevent caches from serving a cached response without first requiring the user-agent to validate the user identity. This directive can be specified with or without field names. When no field names are included, this directive applies to the entire request or response. When one or more field names are specified in the no-cache directive, the response is cached but the specified fields must be excluded. If the response must include the specified field, then the cache must ensure that the request triggers a revalidation with the origin server. Example: `Cache-Control: no-cache="Set-Cookie"` This directive can be used to prevent sensitive information leakage by requiring the server to confirm the user identity before serving the protected information. While content is not served using the browser's history or back button, a user with disk access can retrieve the content.
no-store To completely disable the caching of requests or responses, the server must specify the no-store directive in the `Cache-Control` header. This directive applies to the entire request and response regardless of whether the directive is sent in the request or the response.

© Copyright 2008-2026 Open Text.

Compliance Failure: Missing Privacy Policy

Explanation

Summary: A privacy policy was not supplied by the web application within the scope of this audit. Many legislative initiatives require that organizations place a publicly accessible document within their web application that defines their website's privacy policy. As a general rule, these privacy policies must detail what information an organization collects, the purpose for collecting it, potential avenues of disclosure, and methods for addressing potential grievances. Various laws governing privacy policies include the Gramm-Leach-Bliley Act, Health Insurance Portability and Accountability Act (HIPAA), the California Online Privacy Protection Act of 2003, European Union's Data Protection Directive and others.
Implication: Most privacy laws are created to protect residents who are users of the website. Hence, organizations from any part of the world must adhere to these laws if they cater to customers residing in these geographical areas. Failing to do so could result in a lawsuit by the corresponding government against the organization.
Execution: All of the web pages accessible within the scope of the scan are sampled for textual content that often constitutes a privacy policy statement. A violation is reported upon completion of the web application crawl without a successful match against any of the web pages. Note that the privacy policy of your application could be located on another host or within a section of the site that was not configured as part of the scan. To validate, please try to access the privacy policy of your website and check to see if it was part of the scan.
Reference Info:
California Online Privacy Protection Act http://oag.ca.gov/privacy/COPPA
National Conference of State Legislation http://www.ncsl.org/issues-research/telecom/state-laws-related-to-internet-privacy.aspx
Gramm-Leach-Bliley Act http://www.gpo.gov/fdsys/pkg/PLAW-106publ102/pdf/PLAW-106publ102.pdf
Health Insurance Portability and Accountability Act of 1996 https://www.cms.gov/Regulations-and-Guidance/HIPAA-Administrative-Simplification/HIPAAGenInfo/downloads/HIPAALaw.pdf
Health Insurance Portability and Accountability Act of 1996 http://ec.europa.eu/justice/policies/privacy/docs/guide/guide-ukingdom_en.pdf

Recommendation

Declare a comprehensive privacy policy for the website, and ensure that it is accessible from every page that seeks personal information from users. To verify the fix, rescan the site in order to discover and audit the newly added resources.
Descriptions: Any standard web application privacy policy should include the following components:
- A description of the intended purpose for collecting the data.
- A description of the use of the data.
- Methods for limiting the use and disclosure of the information.
- A list of the types of third parties to whom the information might be disclosed.
- Contact information for inquires and complaints.

© Copyright 2008-2026 Open Text.

HLI: Detected Libraries : React v19.3.0

Explanation

Summary: Hacker Level Insights provides developers and security professionals with more context relating to the overall security posture of their application. The
React version
19.3.0 was detected to be in use by during this scan. While these findings do not necessarily represent a security vulnerability, it is important to note that attackers commonly perform reconnaissance of their target in an attempt to identify known weaknesses or patterns. Knowing what the hacker can see provides context which can help teams better secure their applications.

Recommendation

© Copyright 2008-2026 Open Text.

HTML5: CORS Unsafe Methods Allowed

Explanation

Summary: A resource on the target domain has been found to be shared using CORS. The Access-Control-Allow-Methods header, as reflected in the preflight response for the requested resource, indicates that it allows unsafe HTTP methods. An attacker can use HTTP methods such as PUT or DELETE to make unexpected modifications to shared resource and pose a security threat to the overall site security. A user agent rejects any request for this resource with an HTTP method other than the ones that are listed in the Access-Control-Allow-Methods response header. Cross-Origin Resource Sharing, commonly referred to as CORS, is a technology that allows a domain to define a policy for its resources to be accessed by a web page hosted on a different domain using cross domain XML HTTP Requests (XHR). Historically, the browser restricts cross domain XHR requests to abide by the same origin policy. At its basic form, the same origin policy sets the script execution scope to the resources available on the current domain and prohibits any communication to domains outside this scope. Therefore, execution and incorporation of remote methods and functions hosted on domains outside of the current domain are effectively prohibited. While CORS is supported on all major browsers, it also requires that the domain correctly defines the CORS policy in order to have its resources shared with another domain. These restrictions are managed by access policies typically included in specialized response headers, such as:

- Access-Control-Allow-Origin
- Access-Control-Allow-Headers
- Access-Control-Allow-Methods

Implication: Allowing unsafe HTTP methods such as PUT or DELETE allows opportunities that can be exploited for modification of the resource shared using CORS. An attacker can inject malicious code, backdoor, deface site, or delete and lock resources to cause denial of service attacks.
Reference Info: OWASP HTML 5 Security Cheat Sheet https://www.owasp.org/index.php/HTML5_Security_Cheat_Sheet Cross-Origin Resource Sharing http://en.wikipedia.org/wiki/Cross-origin_resource_sharing http://www.w3.org/TR/cors/ Same Origin Policy http://en.wikipedia.org/wiki/Same_origin_policy WebDAV http://tools.ietf.org/html/rfc2518 http://www.webdav.org/

Recommendation

Review your Cross-Origin-Resource-Sharing policy and consider removing unsafe http methods from Access-Control-Allow-Methods list.
Example 1: An example of IIS server configuration for listing methods the application is allowed to communicate with. <configuration> <system.webServer> <httpProtocol> <customHeaders> <add name="Access-Control-Allow-Methods" value="GET,POST,OPTIONS,HEAD" /> </customHeaders> </httpProtocol> < system.webServer> </configuration> Example 1 shows how to configure CORS headers at server level. However the preferred method is to make use of the API of the language used to code the application and provide this access on each resource shared. Here are some programmatic samples by language:

- **.NET:** Append Header: Response.AppendHeader("Access-Control-Allow-Methods", "GET,POST,OPTIONS,HEAD"); Check for cross domain XHR request: if((Request.Headers["X-Requested-With"] == "XMLHttpRequest") && Request.Headers[“Origin”] != null))

© Copyright 2008-2026 Open Text.

- **Java:** response.addHeader("Access-Control-Allow-Methods", "GET,POST,OPTIONS,HEAD"); check for cross domain XHR request: if((request.getHeader("X-Requested-With") == "XMLHttpRequest") && request.getHeader("Origin")!= null))
- **PHP:** header('Access-Control-Allow-Methods: GET,POST,OPTIONS,HEAD'); ?> Check for cross domain XHR request: If(isset($_SERVER['HTTP_X_REQUESTED_WITH']) && ($_SERVER['HTTP_X_REQUESTED_WITH'] == 'XMLHttpRequest') && isset($_SERVER['Origin']))

© Copyright 2008-2026 Open Text.

HTML5: Misconfigured Content Security Policy

Explanation

Summary: Content Security Policy (CSP) is an HTTP response header that provides in-depth protection from critical vulnerabilities such as cross-site scripting (XSS) and clickjacking. Inline inclusion of JavaScript in HTML content is considered harmful as a large number of exploited XSS are delivered as inline code. Functions such as eval(), window.setTimeout(), and window.setImmediate() create and execute JavaScript code from strings and are considered dangerous. The CSP header disallows inclusion of inline JavaScript and unsafe eval functions. However, using `unsafe-inline` and `unsafe-eval` values for the script-src directive can bypass that restriction. Carefully consider the use of these values because it significantly weakens the protection provided by the CSP header.
Implication: Inline JavaScript code and dynamic evaluation of strings as JavaScript code using functions such as eval(), setTimeout(), and setImmediate() is considered dangerous. A majority of the XSS exploits are delivered and executed using these mechanisms. Disabling the protection provided by the CSP header using `unsafe-inline` and `unsafe-eval` values for the CSP directives can remove a layer of security provided by CSP against these attacks.
Execution: Access link / through a proxy and notice the `unsafe-inline` and/or `unsafe-eval` in the CSP header in the response. By default, WebInspect flags only one instance of this vulnerability per host because it is typical to set this header at the host level in a server configuration. Perform the following steps to flag all instances of this issue:

- Create a new policy with the selection of checks that you want to include in a rescan. We recommend using the Blank or Passive policy as a base.
- Select this check and uncheck the “FlagAtHost” check input from standard description.
- Save the policy.
- Rescan with this new custom policy.

Reference Info: Content Security Policy Level 3 OWASP Content Security Policy MDN web docs Content Security Policy (CSP) Quick Reference Guide

Recommendation

Remove the unsafe-eval and unsafe-inline values from the CSP directive values.

© Copyright 2008-2026 Open Text.

Insecure Transport: HSTS not Set

Explanation

Summary: Http Strict Transport Security (HSTS) policy enables web applications to enforce web browsers to restrict communication with the server over an encrypted SSL/TLS connection for a set period. Policy is declared via special Strict Transport Security response header. Encrypted connection protects sensitive user and session data from attackers eavesdropping on network connection. Consider following attack scenarios:

- Users often omit the URI scheme i.e. https:// when typing a URL in location bar to access a website. Also third party websites can link to the site using the “http” scheme instead of ""https”. This could result in an initial connection to a HTTPS-enabled site over an unencrypted channel. An eavesdropping attacker can hijack this unencrypted connection and replace the intended use of HTTPS protocol with HTTP in an attack known as SSLStrip, granting unauthorized access to all subsequent traffic.
- Websites often transfer non-sensitive resources such as help documents over an unencrypted HTTP connection. Any cookies without a secure flag are sent along with such requests potentially disclosing sensitive user and session data to eavesdropper.
- Man-in-the-Middle attacks that exploit user tendencies to override invalid certification warnings, e.g. SSLSniff.

For web sites configured with an accurate HSTS policy, browsers automatically upgrade any HTTP connections to HTTPS. Furthermore, browsers prevent users from overriding any host certificate warnings. HSTS offers an effective defense against above attack scenarios.
Implication: A successful MiTM attack such as SSLStrip or SSLsniff can lead to the compromise of sensitive user data such as financial information, Social Security Number, personal information etc. as well as grant unauthorized access to user accounts enabling attackers to perform privileged actions on client’s behalf.
Execution: Access location /assets/jsx-runtime-D3jfb0Ew.js and notice the absence of the Strict Transport Security header in the HTTP response.
Reference Info: http://tools.ietf.org/html/rfc6797

Recommendation

Configure the web application under test to include Strict Transport Security header in every response generated by an HTTPS-enabled site. Any HTTP version of site on the same domain should permanently redirect to the secure encrypted site. Header should not be added to HTTP response as browsers will ignore it. It is important to note that this header does not prevent from above mentioned attack scenarios during the very first connection to the site or any connections established after the set period has expired. To prevent such a scenario, the site must be added to the pre-loaded HSTS hosts list embedded in both Google Chrome and Mozilla Firefox browsers.

© Copyright 2008-2026 Open Text.

Often Misused: File Upload

Explanation

Summary: Permitting users to upload files may allow attackers to inject dangerous content or malicious code to run on the server. WebInspect has detected file upload capabilities on this server. As part of the Dangerous File Upload check, WebInspect may have uploaded multiple files to the server. All files uploaded as part of this test have filenames in the format WebInspect_ccccc_File_nn.extension Where: ccccc = WebInspect Check ID Number nn = Unique random number Please locate and delete these files on the server after testing is completed.
Implication: Regardless of the language in which a program is written, the most devastating attacks often involve remote code execution, whereby an attacker succeeds in executing malicious code in the program's context. If attackers are allowed to upload files to a directory that is accessible from the Web and cause these files to be passed to a code interpreter (e.g. JSP/ASPX/PHP), then they can cause malicious code contained in these files to execute on the server. The exact implications depend upon the nature of the files an attacker would be able to upload. Implications range from unauthorized content publishing to aid in phising attacks, all the way to full compromise of the web server. Even if a program stores uploaded files under a directory that isn't accessible from the Web, attackers might still be able to leverage the ability to introduce malicious content into the server environment to mount other attacks. If the program is susceptible to path manipulation, command injection, or dangerous file inclusion vulnerabilities, then an attacker might upload a file with malicious content and cause the program to read or execute it by exploiting another vulnerability.
Reference Info: Secure file upload in PHP web applications Standards Mapping - Common Weakness Enumeration - (CWE) CWE ID 434 OWASP Unrestricted File Upload

Recommendation

Do not accept attachments if they can be avoided. If a program must accept attachments, then restrict the ability of an attacker to supply malicious content by only accepting the specific types of content the program expects. Most attacks that rely on uploaded content require that attackers be able to supply content of their choosing. Placing restrictions on the content the program will accept will greatly limit the range of possible attacks. Check file names, extensions, and file content to make sure they are all expected and acceptable for use by the application. Make it difficult for the attacker to determine the name and location of uploaded files. Such solutions are often program-specific and vary from storing uploaded files in a directory with a name generated from a strong random value when the program is initialized, to assigning each uploaded file a random name and tracking them with entries in a database. Ensure that the following steps are taken to sanitize the file being received:

- Limit the types of files that can be uploaded. For instance, on an image upload page, any file other than a .jpg should be refused.
- Ensure that the web user has no control whatsoever over the name and location of the uploaded file on the server.
- Never use the name that the user assigns it.
- Never derive the filename from the web user's username or session ID.
- Do not place the file in a directory accessible by web users. It is preferable for this location to be outside of the webroot.
- Ensure that strict permissions are set on both the uploaded file and the directory it is located in.
- Do not allow execute permissions on uploaded files. If possible, deny all permission for all users but the web application user.
- Verify that the uploaded file contains appropriate content. For instance, an uploaded JPEG should have a standard JPEG file header.

© Copyright 2008-2026 Open Text.

Often Misused: Weak SSL Certificate

Explanation

Summary: WebInspect has identified an unverified certificate served from the target server. Server certificates declare the public key of the server for use in transport layer security. Trusted third-party vendors known as Certificate Authority (CA) sign and issue the certificates to ensure that they are authentic and contain the public key of the intended server. The public key of the root CA is embedded in the operating system (OS) by the vendor (e.g., in Windows by Microsoft or in Mac OS by Apple). Upon receipt of a certificate, the client (e.g., a web browser) verifies the identity with the OS's embedded trusted CA. In case of an unverified certificate, the certificate's chain of trust cannot be validated, either because it is signed by an unknown or untrusted CA, has missing intermediate certificates, or has other chain validation failures. This prevents the client from verifying its authenticity with a trusted CA. Since there is no third-party verification possible, an attacker can mount a man-in-the-middle impersonation attack by issuing a certificate with fake details and a public key that the attacker controls. The client generates a security warning for an unverified certificate, which a user can override. Users can inspect the certificate before allowing it to be trusted. However, a legitimate unverified certificate from the intended site can encourage an insecure practice of overriding unverified certificate warnings without inspecting details, which in turn can make users more susceptible to impersonation attacks.
Implication: An attacker can perform a successful man-in-the-middle attack, luring users to communicate with fake sites and in turn compromising secrecy and integrity of sensitive data. Further, since the certificate's chain of trust cannot be properly verified, users have no reliable way to distinguish between a legitimate unverified certificate and a malicious one. A security issue affecting the certificate infrastructure could require servers to update their certificate chains to ensure proper validation.
Execution: Browse to /assets/search-Dx8hvHZn.js. Inspect the certificate chain and verify that the certificate's issuer can be validated against trusted root certificates in the system's certificate store.
Reference Info:
OWASP: Transport Layer Protection Cheat Sheet https://www.owasp.org/index.php/Transport_Layer_Protection_Cheat_Sheet
How Certificate Chains Work https://knowledge.digicert.com/solution/how-certificate-chains-work

Recommendation

Replace unverified certificate with a certificate authority (CA) signed certificate. Ensure all intermediate certificates are properly included in the certificate chain. Production environment should not deploy unverified certificates.

© Copyright 2008-2026 Open Text.

Path Manipulation: Special Characters

Explanation

Summary: Control characters such as 0x09 should not be allowed in a URL path and must be percent-encoded by clients. The inconsistent parsing of these control characters between proxy and backend server might introduce various threats.
Implication: Attackers might manipulate control characters in the URL path. The implication varies depending on the context of the vulnerability, and the business logic of the application. However, in most cases, attackers insert control characters in different positions of the URL path to bypass authentication or restrictions.
Execution: The following is an example of how a simple attack might occur. Suppose there is an Gunicorn application that is behind a proxy server. The proxy server accepts control characters such as 0x09 in the URL path. In the proxy configuration, access of the endpoint `/secret` is not allowed. When an attacker sends the following request `http://example.com/secret0x09HTTP/1.1/../../public` , the proxy normalizes the URL to `http://example.com/public`, which is allowed access. The proxy then forwards the original request to the backend Gunicorn application. The backend application considers the 0x09 character as a separator between the URL path and HTTP protocol version. The application therefore believes that the user is trying to access `http://example.com/secret` and returns the content of the endpoint `/secret` to the attacker. In the current scan, user can request the URL `/assets/triangle-alert-BfPUAUia.js0x09HTTP/1.1/../../` to check if could be allowed to be inserted in the URL path. If the remote server responc with same page as requesting the original URL, then the control character is allowed to be inserted in the URL path. This example shows that an attacker can bypass authentication or achieve other successful attacks by manipulating the control characters in the URL path.
Reference Info: Disabled control characters in URIs. CHYbeta/OddProxyDemo

Recommendation

Disable all possible control characters (0x00 – 0x1f, 0x7f) in the URL path. For example, the following configuration could be added into nginx.conf file to forbid control character 0x09. `if ($request_uri ~* .*[\x09]+.*) {return 435;}` It is also accepted if add similar access control policy in the firewall which is deployed before the backend application server.

© Copyright 2008-2026 Open Text.

Web Server Misconfiguration: Insecure Content-Type Setting

Explanation

Summary: The Content-Type HTTP response header or the HTML meta tag provides a mechanism for the server to specify an appropriate character encoding for the response content to be rendered in the web browser. Proper specification of the character encoding through the charset parameter in the Content-Type field reduces the likelihood of misinterpretation of the characters in the response content and ensure reliable rendering of the web page.Failure to ensure enforcement of the desired character encoding could result in client-side attacks like Cross-Site Scripting.
Implication: In the absence of the character set specification, a user-agent might default to a non-standard character set, or could derive an incorrect character set based on certain characters in the response content. In some cases, both these approaches can cause the response to be incorrectly rendered. This may enable other attacks such as Cross-site Scripting.
Execution: Verify the character set specification on every HTTP response. Character sets can be specified in the HTTP header or in an HTML meta tag. In the case of an XML response, the character set can be specified along with the XML Declaration.
Reference Info:
DoD Application Security and Development STIG http://iase.disa.mil/stigs/app_security/app_sec/app_sec.html
UTF-7 encoding used to create XSS attack http://www.securityfocus.com/archive/1/420001

Recommendation

Ensure that a suitable character set is specified for every response generated by the web application. This can be done either by,

- Modifying the code of the web application, which would require all pages to be modified.
- Adding Content-Type header to the server configuration (**recommended**). This ensures that the header is added to all the responses with minimal development effort.

© Copyright 2008-2026 Open Text.

Web Server Misconfiguration: Server Error Message

Explanation

Summary: A server error response was detected. The server could be experiencing errors due to a misbehaving application, a misconfiguration, or a malicious value sent during the auditing process. While error responses in and of themselves are not dangerous, per se, the error responses give attackers insight into how the application handles error conditions. Errors that can be remotely triggered by an attacker can also potentially lead to a denial of service attack or other more severe vulnerability. Recommendations include designing and adding consistent error handling mechanisms which are capable of handling any user input to your web application, providing meaningful detail to end-users, and preventing error messages that might provide information useful to an attacker from being displayed.
Implication: The server has issued a 500 error response. While the body content of the error page may not expose any information about the technical error, the fact that an error occurred is confirmed by the 500 status code. Knowing whether certain inputs trigger a server error can aid or inform an attacker of potential vulnerabilities.
Reference Info:
Apache: Security Tips for Server Configuration Protecting Confidential Documents at Your Site Securing Apache - Access Control
Microsoft: How to set required NTFS permissions and user rights for an IIS 5.0 Web server Default permissions and user rights for IIS 6.0 Description of Microsoft Internet Information Services (IIS) 5.0 and 6.0 status codes

Recommendation

For Security Operations: Server error messages, such as "File Protected Against Access", often reveal more information than intended. For instance, an attacker who receives this message can be relatively certain that file exists, which might give him the information he needs to pursue other leads, or to perform an actual exploit. The following recommendations will help to ensure that a potential attacker is not deriving valuable information from any server error message that is presented.

- Uniform Error Codes: Ensure that you are not inadvertently supplying information to an attacker via the use of inconsistent or "conflicting" error messages. For instance, don't reveal unintended information by utilizing error messages such as Access Denied, which will also let an attacker know that the file he seeks actually exists. Have consistent terminology for files and folders that do exist, do not exist, and which have read access denied.
- Informational Error Messages: Ensure that error messages do not reveal too much information. Complete or partial paths, variable and file names, row and column names in tables, and specific database errors should never be revealed to the end user. Remember, an attacker will gather as much information as possible, and then add pieces of seemingly innocuous information together to craft a method of attack.
- Proper Error Handling: Utilize generic error pages and error handling logic to inform end users of potential problems. Do not provide system information or other data that could be utilized by an attacker when orchestrating an attack.

Removing Detailed Error Messages Find instructions for turning off detailed error messaging in IIS at this link: http://support.microsoft.com/kb/294807
For Development: From a development perspective, the best method of preventing problems from arising from server error messages is to adopt secure programming techniques that prevent problems that might arise from an attacker discovering too much information about the architecture and design

© Copyright 2008-2026 Open Text.

of your web application. The following recommendations can be used as a basis for that.

- Stringently define the data type (for instance, a string, an alphanumeric character, etc) that the application will accept.
- Use what is good instead of what is bad. Validate input for improper characters.
- Do not display error messages to the end user that provide information (such as table names) that could be utilized in orchestrating an attack.
- Define the allowed set of characters. For instance, if a field is to receive a number, only let that field accept numbers.
- Define the maximum and minimum data lengths for what the application will accept.
- Specify acceptable numeric ranges for input.

For QA: The best course of action for QA associates to take is to ensure that the error handling scheme is consistent. Do you receive a different type of error for a file that does not exist as opposed to a file that does? Are phrases like "Permission Denied" utilized which could reveal the existence of a file to an attacker? Inconsistent methods of dealing with errors gives an attacker a very powerful way of gathering information about your web application.

© Copyright 2008-2026 Open Text.

Web Server Misconfiguration: Unprotected Directory

Explanation

Summary: Administrative directories were discovered within your web application during a Directory Enumeration scan. Risks associated with an attacker discovering an administrative directory on your application server typically include the potential for the attacker to use the administrative applications to affect the operations of the web site. Recommendations include restricting access to important directories or files by adopting a "need to know" requirement for both the document and server root, and turning off features such as Automatic Directory Listings that provide information that could be utilized by an attacker when formulating or conducting an attack.
Implication: The primary danger from an attacker finding a publicly available directory on your web application server depends on what type of directory it is, and what files it contains. Administrative directories typically contain applications capable of changing the configuration of the running software; an attacker who gains access to an administrative application can drastically affect the operation of the web site.
Reference Info:
Implementing Basic Authentication in IIS https://learn.microsoft.com/en-us/iis/configuration/system.webserver/security/authentication/basicauthentication
Implementing Basic Authentication in Apache http://httpd.apache.org/docs/howto/auth.html#intro

Recommendation

For Security Operations: You should evaluate the production requirements for the found directory. If the directory is not required for production operation, then the directory and its contents should be removed or restricted by a server access control mechanism. More information about implementing access control schemes can be found in the References. Automatic directory indexing should also be disabled, if applicable.
For Development: This problem will be resolved by the web application server administrator. In general, do not rely on 'hidden' directories within the web root that can contain sensitive resources or web applications. Assume an attacker knows about the existence of all directories and files on your web site, and protect them with proper access controls.
For QA: This problem will be resolved by the web application server administrator.

© Copyright 2008-2026 Open Text.

Web Server Misconfiguration: Weak Authentication

Explanation

Summary: The web server sent a 401 "Authorization Required" status code with a response that did not contain a WWW-Authenticate HTTP header. This means the server is asking for authentication, but the browser is not prompting for authentication because of the missing WWW-Authenticate header. Recommendations include reviewing the web pages to determine if they should be protected via authentication, and correct the web server or application configuration to correct the problem by setting the 401 "Authorization Required" status code or by removing the WWW-Authenticate header.
Implication: To prompt for user authentication, a web server must send a 401 "Authorization Required" status code, along with a WWW-Authenticate HTTP header. This could mean portions of the web site are available that should require authentication, or this may simply be a misconfiguration at the application or web server level.
Reference Info:
RFC-2616 Section 10.4.2: 401 Unauthorized Section 14.47: WWW-Authenticate

Recommendation

For Security Operations: Review the web pages to determine if they should be protected via authentication, and correct the web server or application configuration to correct the problem by sending a WWW-Authenticate header or by changing the 401 "Authorization Required" status code to a different status.
For Development: Review the web pages to determine if they should be protected via authentication, and correct the web server or application configuration to correct the problem by sending a WWW-Authenticate header or by changing the 401 "Authorization Required" status code to a different status.
For QA: Review the web pages to determine if they should be protected via authentication, and correct the web server or application configuration to correct the problem by sending a WWW-Authenticate header or by changing the 401 "Authorization Required" status code to a different status.

© Copyright 2008-2026 Open Text.